

Full Length Article

An integrated framework for information security risk management: A mixed-methods systematic literature review

Biju B Varghese^{*}, Quang Neo Bui^{ID}

Rochester Institute of Technology, 105 Lomb Memorial Drive, Rochester, NY 14623, USA

ARTICLE INFO

Keywords:

ISRM
Information security risk management
Systematic literature review
Mixed-methods

ABSTRACT

Driven by escalating threats and regulatory scrutiny, information security risk management (ISRM) is now a strategic imperative for organizations across the industrial spectrum. Although prior literature reviews offer valuable insights into ISRM subdomains, they remain fragmented and overly reliant on manual methods, limiting their scope and scalability. Additionally, only limited reviews have been able to comprehensively synthesize ISRM literature across its three foundational pillars: processes, governance, and strategy. To address this gap, we conduct a large-scale systematic literature review of 623 ISRM-related articles using a mixed-methods approach which combines natural language processing techniques with thematic analysis. We identify 22 thematic clusters and aggregate them into an integrated framework comprising three interdependent perspectives: Technical, Socio-Behavioral, and Strategic & Governance. Our integrated framework bridges disciplinary silos to inform research opportunities at the intersection of technical controls, human behavior, and strategic oversight.

1. Introduction

Driven by the growing prevalence of data breaches, ransomware attacks, and phishing attempts, information security risk management (ISRM) has become a core strategic concern¹ for modern organizations. The Ponemon Institute's (Ponemon Institute, 2025) Cybersecurity Threat and Risk Management Report estimates the average global cost of a data breach at \$4.45 million, underscoring the substantial economic burden of information security lapses. Beyond direct financial losses, firms grapple with regulatory fines, reputational harm, and erosion of market valuation (Anderson et al., 2013; Janakiraman et al., 2018). In response to mounting pressure for greater transparency regarding ISRM by firms, the U.S. Securities and Exchange Commission (SEC) introduced new cybersecurity disclosure guidelines in 2023.² These developments signal a realization among regulators and corporate management teams that robust ISRM now extends beyond purely technical concerns to require effective management processes, governance, and strategic alignment (Baskerville, 2008; COBIT 5; FAIR; NIST CSF 2.0).

Since Baskerville's (1991) foundational work, the field of ISRM has witnessed a substantial accumulation of research across diverse domains, with several subsequent systematic literature reviews (SLRs).

Although these SLRs collectively offer valuable insights into key ISRM subdomains, such as IT governance (De Smet and Mayer, 2016), capabilities embedded in ISRM (Lundgren, 2020), sector-specific challenges (Alahmari and Duncan, 2020; Bhatti et al., 2021), and risk assessment methodologies (Devi et al., 2022; Pan and Tomlinson, 2016; Shame-li-Sendi, 2020), they do not provide a holistic perspective encompassing all the three key ISRM areas of processes, governance, and strategy. The fragmented scope of existing reviews results in an incomplete understanding of the field of ISRM. Furthermore, all these prior literature reviews have largely relied on manual curation and topic exploration as their methodology, limiting their capacity to analyze large volumes of articles comprehensively.

To bridge these gaps, we seek to synthesize an integrated understanding of ISRM that spans technical processes, organizational governance, and strategic alignment facets. Our review is guided by two primary research questions:

RQ1. *What are the existing themes in ISRM literature across three key areas of processes, governance, and strategy?*

RQ2. *What future research directions in ISRM literature warrant greater consideration?*

^{*} Corresponding author.

E-mail addresses: bv8145@rit.edu (B.B. Varghese), qnbbbu@rit.edu (Q.N. Bui).

¹ <https://aspr.hhs.gov/S3/Pages/Information-Security.aspx>

² <https://www.federalregister.gov/documents/2023/08/04/2023-16194/cybersecurity-risk-management-strategy-governance-and-incident-disclosure>

To explore these research questions, we adopt a mixed-methods approach that integrates natural language processing (NLP) techniques with qualitative analysis. This approach enables us to analyze hundreds of publications in a more comprehensive manner than either manual or computational reviews alone, highlighting topics, methodological and theoretical trends, and areas for future investigation. Our review corpus consists of 623 articles, revealing thematic patterns that would be challenging to identify through manual methods alone. We further conducted a gap analysis based on a thorough examination of 47 highly cited studies across the identified themes, allowing us to identify research opportunities that span across domains and enrich the current ISRM knowledge base.

This article makes several contributions to research and practice. First, our review presents an integrated framework that synthesizes the fragmented ISRM literature into three cohesive perspectives: Technical, Socio-Behavioral, and Strategic & Governance. Unlike prior reviews that often examine these domains in isolation, our framework elucidates the interdependencies between technical mechanisms, human factors, and organizational oversight, offering an integrated structure for understanding how these elements jointly shape information security risk outcomes. Second, we advance the methodology of literature reviews in information security by demonstrating a novel mixed-methods approach. By synergizing NLP with rigorous qualitative coding, we overcome the scalability limitations of traditional manual reviews while retaining the contextual depth often lost in purely bibliometric analyses. Third, based on a mapping of the literature to the NIST Cybersecurity Framework (NIST CSF, 2.0), we identify and articulate critical asymmetries in current research, most notably a predominant focus on preventative measures (Identify and Protect) at the expense of post-incident resilience (Detect, Respond and Recover).

The remainder of this article is structured as follows: First, we review the literature on ISRM and related SLRs, illustrating their insights and limitations. We then detail our research methodology, describing both the computational pipeline and qualitative coding used to analyze and cluster ISRM topics. We then present our findings, outlining dominant themes, publication trends, and an integrated ISRM framework. Finally, we explore the implications of these insights and propose directions for future IS research in ISRM.

2. Background: ISRM literature reviews

ISRM is a critical, continuous process enabling organizations to identify, analyze, and control risks to their information assets, from sensitive data to intellectual property and strategic resources (Spears and Barki, 2010). Effective ISRM is fundamental to organizational success, protecting against threats that could compromise data integrity, confidentiality, and availability (Anderson and Choobineh, 2008). In organizational environments, ISRM efforts are organized into key areas of Processes, Governance, and Strategy (Baskerville, 2008; COBIT 5; ISO/IEC 27005; FAIR; Goodman et al., 2016; NIST CSF 2.0). *ISRM Processes* involve systematic identification, analysis, evaluation, treatment, communication, and continuous monitoring of cybersecurity risks (NIST CSF 2.0; ISO/IEC 27005). *ISRM Governance* refers to accountability structures, roles and responsibilities, and oversight mechanisms (e.g., governance boards and risk management frameworks) to ensure that information security practices follow regulatory requirements and enterprise risk management (NIST CSF 2.0; COBIT 5). *ISRM Strategy* emphasizes alignment of security initiatives with broader organizational goals, including clear strategic plans that establish desired security capabilities, maturity targets, performance indicators, and risk tolerance thresholds to support business resilience (COBIT 5; FAIR; ISACA, 2010).

Over time, these key areas have expanded extensively, with the development of diverse methodologies and frameworks designed to address increasingly complex information security challenges. This growth in the field of ISRM is evident in the research literature, with numerous SLRs, narrative reviews, and bibliometric studies delineating

key themes, integration challenges, and gaps within ISRM practices. An overview of existing literature reviews in the field of ISRM is presented in Table 1.

The existing reviews of ISRM provide valuable insights, but they also reveal discernible limitations in scope, resulting in a fragmented understanding of the field. A collective overview of their coverage indicates a number of gaps across the key ISRM areas. While the majority of reviews focus on ISRM processes (e.g., Devi et al., 2022; Fenz et al., 2014), only a few explore ISRM strategy (e.g., Bhatti et al., 2021; Lundgren, 2020; Mızrak, 2023), and reviews addressing ISRM governance remain particularly sparse (e.g., De Smet and Mayer, 2016). This differential coverage of the critical dimensions of ISRM suggests an opportunity for an integrated perspective on the phenomenon. Addressing this under-representation, our study provides a systematic review that comprehensively examines all three of the key ISRM areas.

In terms of methodologies, existing ISRM reviews reflect three general approaches: SLR, narrative review, and bibliometric review, with SLR as the dominant approach. SLRs provide “a systematic, explicit, [comprehensive,] and reproducible method for identifying, evaluating, and synthesizing the existing body of completed and recorded work produced by researchers, scholars, and practitioners” (Fink, 2019). By consolidating a broad array of studies, SLRs enable researchers to identify gaps, assess research rigor, and structure the knowledge base around a phenomenon. This approach allows for a comprehensive understanding of ISRM practices and their applications. For instance, De Smet and Mayer (2016) emphasize the importance of aligning IT governance with risk management through standardized models and highlight the pivotal role of IT risk managers in decision-making. Lundgren (2020) uses a concept-centric approach to explore embedded capabilities in ISRM, stressing adaptable controls and consistent stakeholder engagement. Several SLRs address sector-specific challenges, ranging from the distinct risk management needs of SMEs and IT outsourcing environments to ISRM methodologies within cloud computing contexts (Alahmari and Duncan, 2020; Alcántara and Melgar, 2016; Amraoui et al., 2019; Bhatti et al., 2021). Some also provide taxonomies that guide organizations in tailoring Information Security Risk Assessment approaches to their unique risk profiles (Shameli-Sendi et al., 2016; Pan and Tomlinson, 2016; Devi et al., 2022).

In addition to SLRs, several narrative and descriptive reviews (Paré et al., 2015) explore limitations and propose optimization strategies across current practices by employing comparative analysis of ISRM methods (Fenz et al., 2014) and chronological and thematic overviews of cyber risk management (Eling et al., 2021). Other narrative reviews integrate ISRM with strategic management and enterprise architecture (Diefenbach et al., 2019; Mızrak, 2023). Bibliometric studies provide additional insights by mapping the structure and evolution of ISRM by employing scientometric tools to identify key trends and influential frameworks within ISRM (Cucus et al., 2023). Notably, the majority of extant reviews rely on manual processes for article selection and topic exploration, which are less scalable with a large corpus of literature. When applied to an expansive, interdisciplinary domain like ISRM, manual processes are inhibited by the considerable time and effort needed to appraise hundreds of articles, the heightened risk of overlooking relevant studies, and potential researcher biases. A literature review that synthesizes this extensive body of work could offer valuable insights and guide future research. To address this need, we adopt a computational approach leveraging machine learning techniques to analyze extensive unstructured data. This is complemented by qualitative analysis of representative documents to ensure contextual depth. Combining computational efficiency with qualitative insights, our mixed-methods approach enables the dynamic synthesis of the literature, including topic evolution, pattern detection, and thematic analysis.

3. Method

Following the typology of literature reviews of Pare (2015), our

Table 1
Summary of ISRM literature reviews.

Papers	ISRM Key Areas			Methodology		
	ISRM Process	ISRM Governance	ISRM Strategy	SLR	Narrative review	Bibliometric review
Fenz et al. (2014)	✓		✓		✓	
De Smet & Mayer. (2016)		✓		✓		
Alcántara & Melgar. (2016)	✓			✓		
Pan & Tomlinson. (2016)	✓			✓		
Shameli-Sendi et al. (2016)	✓			✓		
Amraoui et al. (2019)	✓			✓		
Diefenbach et al. (2019)	✓				✓	
Lundgren. (2020)			✓	✓		
Alahmari & Duncan. (2020)	✓			✓		
Bhatti et al. (2021)	✓		✓	✓		
Eling et al. (2021)	✓	✓			✓	
Devi et al. (2022)	✓			✓		
Cucus et al. (2023)			✓			✓
Mizrak (2023)			✓		✓	

literature review falls under the “descriptive” type, which “seek[s] to determine the extent to which a body of empirical studies in a specific research area supports or reveals any interpretable patterns or trends with respect to pre-existing propositions, theories, methodologies, or findings” (p. 186). In line with a descriptive review, which seeks to form a “representative” view of the literature, we identify and analyze patterns, trends, and methodological developments within a representative sample of the extant ISRM research. To undertake the review, we followed the SLR guidelines by Kitchenham (2004) to design the protocol, search, and screening, and employ the Preferred Reporting Items for Systematic Reviews and Meta-analyses (PRISMA) framework (Page et al., 2021) for reporting the process. We utilize a mixed-methods approach to analyze the dataset, integrating advanced computational techniques with qualitative analysis. We employ NLP techniques by leveraging a cybersecurity domain-specific transformer model to generate document embeddings. These embeddings were subsequently clustered to identify the topics. To ensure the robustness of the analysis, qualitative techniques were applied to interpret the topics and generate deeper insights. Two independent researchers conducted the review to mitigate bias and reduce the likelihood of random or systematic errors (Paré et al., 2016). This methodological approach ensured a rigorous and comprehensive review across disciplinary domains.

3.1. Article selection and dataset creation

We follow the PRISMA framework for the reporting of the rigorous process that guided data collection, screening, identification, and inclusion decisions and procedures. Fig. 1 illustrates our identification, screening, and inclusion stages using the PRISMA flowchart. First, we used the Web of Science and ABI INFORM research databases to collect literature for our dataset, since they are acknowledged as high-quality sources for systematic reviews (Desalegn et al., 2024; Mongeon and Paul-Hus, 2016). The primary search was conducted using the search string TS=((“information security” OR “cybersecurity” OR “cyber threat” OR “cyber risk”) AND (“risk management” OR “isrm” OR “risk assessment” OR “risk identification” OR “threat identification” OR “risk mitigation” OR “risk control” OR “risk management process” OR

“strategy” or “strategies” OR “governance” OR “governance practice” OR “security governance” OR “information security governance” OR “board oversight” OR “management oversight” OR “leadership” OR “board of director” OR “committee” OR “board committee” OR “material risk”)) using keywords derived from prior ISRM literature reviews (Table 1) and widely recognized information security frameworks (NIST CSF 2.0; ISO/IEC 27005; COBIT 5, FAIR). The review was scoped to academic journal articles and conference papers published in English between 2000 and 2025. A total of 8986 articles were identified and subsequently advanced to the screening stage.

In the screening stage, we reviewed the titles and abstracts of each article. Papers within the domain of information security research were retained, while duplicates and those with missing abstracts were removed. This process resulted in 8389 papers advancing to the inclusion stage. Finally, in the inclusion stage, we conducted an eligibility assessment by applying exclusion criteria. Specifically, only articles published in journals classified under the Information Management area of the Academic Journal Guide (AJG) or in the Google Scholar Top Publications in Computer Security were retained.³ Following this assessment, our final dataset comprised 623 papers.

3.2. Data analysis

Our data analysis approach integrates machine learning techniques with qualitative analysis to comprehensively examine the corpus of ISRM literature. We employed advanced computational techniques, specifically NLP using a cybersecurity domain-specific transformer model, to perform topic modeling through clustering of document embeddings. The NLP technique enabled efficient analysis of large volumes of unstructured data, facilitating the discovery of topics that would be challenging to identify through manual methods alone. Following the computational analysis, we conducted manual qualitative examination of representative documents within each identified cluster to interpret

³ https://scholar.google.com/citations?view_op=top_venues&hl=en&vq=eng_computersecuritycryptology

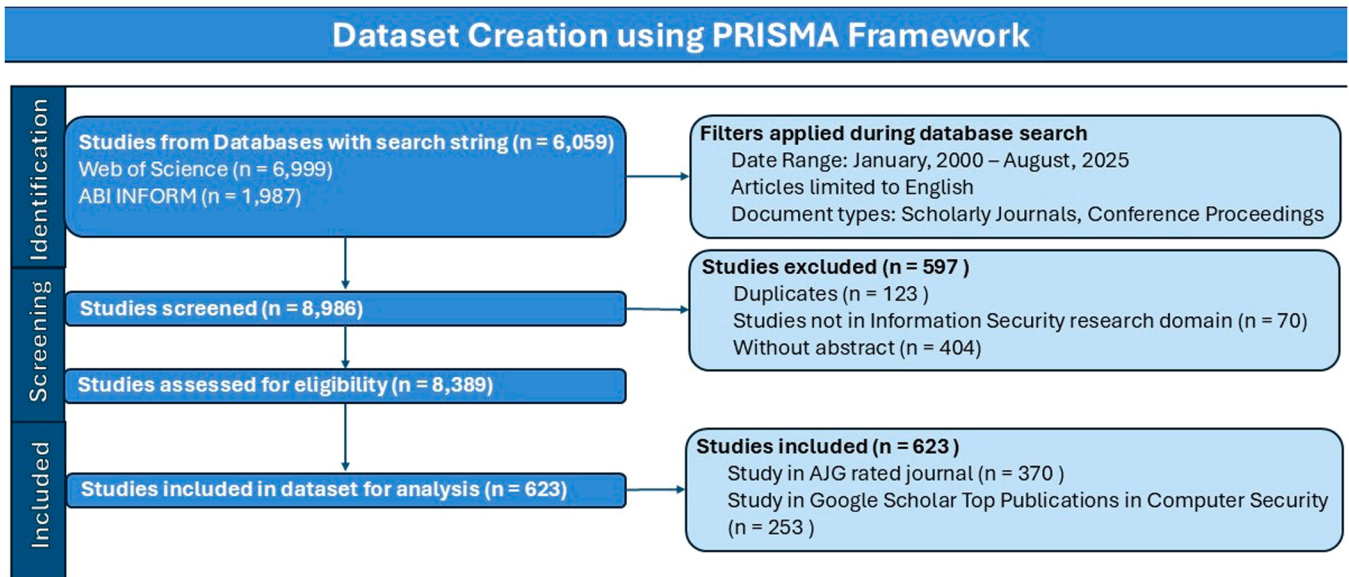


Fig. 1. PRISMA flowchart of article identification, screening and inclusion.

topics in context, resulting in a deeper understanding of the emergent thematic structures. This sequential QUAN→QUAL mixed-methods approach ensures methodological rigor, enabling accurate identification and fine-grained interpretation of underlying thematic patterns. The flow of our mixed-methods analysis is summarized in Fig. 2 and elaborated below:

3.2.1. Generation of embeddings

The first step in our analysis was to transform the textual data into numerical representations suitable for clustering. We use the abstracts of 623 papers for this step (Cao et al., 2023; Sunikka and Bragge, 2012). This research design choice has several advantages over using the full paper texts: (1) it is computationally low cost which allowed us to run faster iteration cycles of refining and testing alternative models; (2) abstracts typically have a cleaner and more concise textual structure (e. g., gap, method, contribution) than full texts which reduces noise in the clustering analysis; and (3) the use of abstracts aligns with the purpose of the first analytical phase, which was to identify research trends, detect thematic patterns, and map the literature landscape.

We used a transformer model, which processes text and generates an embedding vector encapsulating its contents. Traditional methods, such as the bag-of-words (BoW) approach (Zhang et al., 2010), represent text as sparse matrices based on word counts/frequencies. However, these methods treat words independently, disregarding contextual and semantic relationships, such as word order or meaning in different contexts. In contrast, embeddings offer a more sophisticated solution by converting text into continuous vector representations that capture both the meanings of words and their contextual nuances (Gruetzmacher and Paradise, 2022). Unlike BoW, embeddings preserve relationships between similar words and differentiate between terms based on context, allowing for more nuanced analysis with reduced dimensionality. Each abstract was processed through the “cyber-risk-llama-3-8b”, a fine-tuned version of the Meta Llama3 8B model⁴ trained on a cyber-security dataset. This model, selected for its robust training on cyber-security data, is particularly suited to identifying patterns in the ISRM domain. (See Appendix B.2 for a comparison of this model with other choices.) The output of this process is a 4096-dimensional vector for each abstract, providing a high-dimensional representation that encapsulates semantic and contextual information.

3.2.2. Dimensionality reduction and clustering analysis of embeddings

To group similar documents and facilitate topic modeling, we employed clustering techniques on the embeddings of the 623 abstracts. Clustering enhances the feasibility and efficiency of manual analysis by organizing data into manageable groups, simplifying the exploration of key themes and patterns across the dataset. To reduce the dimensionality of paragraph embeddings, we applied the UMAP algorithm (McInnes et al., 2020), which preserves both the local and global structures of high-dimensional data while simplifying its representation. Following dimensionality reduction, we used the HDBSCAN clustering algorithm with a minimum cluster size of six to identify meaningful groups within the data. The choice of a smaller cluster size ensures that smaller but potentially significant clusters are not overlooked. HDBSCAN was selected for clustering due to its ability to automatically determine the optimal number of clusters, handle noise effectively, and accommodate datasets with varying cluster densities. (See Appendix B.1 for more detail on the selection of the optimal number of clusters.) These features make it more suitable for our dataset than algorithms like K-Means, which require predefined cluster numbers and struggle with irregular cluster shapes or noisy data. This resulted in 22 distinct clusters/unique topics within the dataset. The clustering process provides the foundation for the next phase of our method: a detailed qualitative analysis of representative documents within each cluster. This phase aims to uncover deeper insights into the identified topics, including their theoretical frameworks, methodologies, and alignment with NIST categories.

3.2.3. Identifying representative documents of each cluster (i.e., topic)

In the post-HDBSCAN clustering phase, we employed a novel approach to select representative documents for the qualitative analysis phase of the analysis. These representative documents were carefully analyzed for in-depth understanding of the literature.

To identify these representative documents, we used a Topic-Document Probability matrix. This matrix, derived from the soft clustering functionality of HDBSCAN, provides a probabilistic mapping of document membership within clusters. Following the model fit, the probability matrix was accessed using the `all_points_membership_vectors` function.⁵ This function generates a two-dimensional array, representing the probabilistic associations between documents and

⁴ <https://huggingface.co/Vanessasm/cyber-risk-llama-3-8b>

⁵ https://hdbscan.readthedocs.io/en/latest/soft_clustering.html

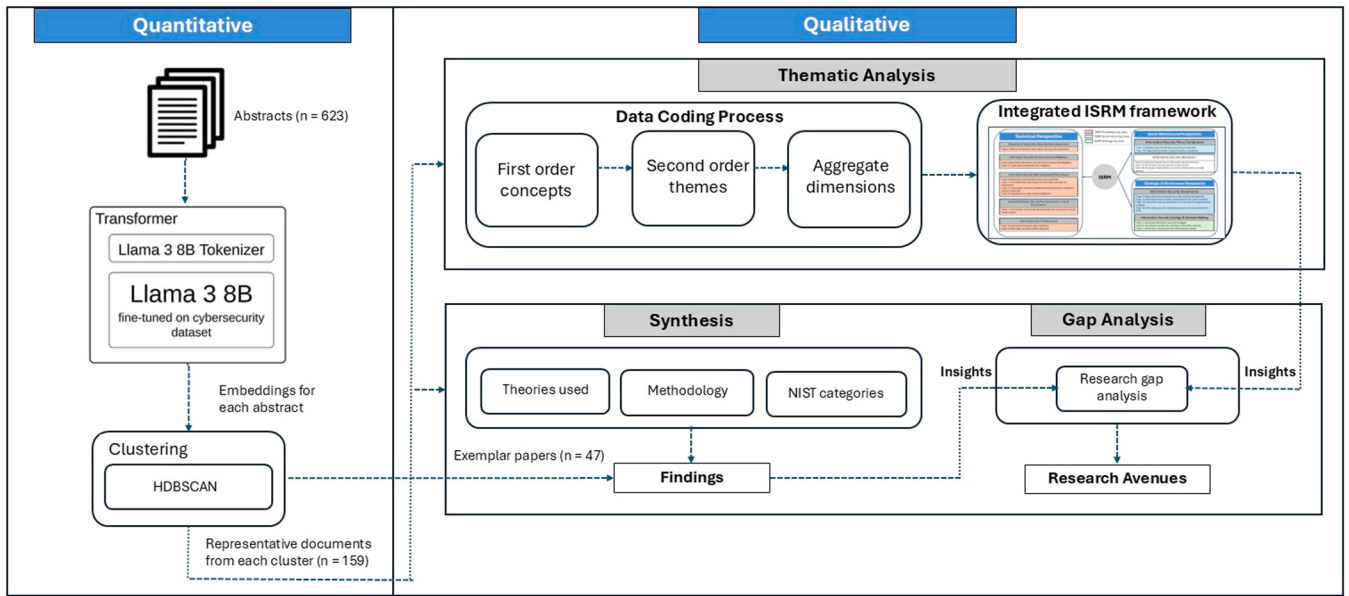


Fig. 2. Mixed method data analysis.

clusters. Each row corresponds to a document, and each column represents a cluster/topic. The values within the matrix indicate the probability of a document belonging to a particular cluster, providing a probabilistic membership measure. This structured representation provides an indication of how documents relate to different topics. The matrix's dimensionality is determined by the number of documents (m) and the number of identified topics (n), resulting in an $m \times n$ matrix with values ranging from 0 to 1 for the topical membership probability. In our case, $m = 623$ documents, and $n = 22$ topics. Fig. 3 provides a sample of the matrix, providing a measure of the semantic unity and internal consistency of documents within topic clusters.

From the topic-document probability matrix, we selected representative documents for each topic. These are documents with a probability of one for each topic/cluster, representing the most archetypal instances within the semantic space that most precisely capture the cluster's underlying conceptual structure. This approach aligns with HDBSCAN's fundamental principle of prioritizing density-connected regions and minimizing noise, effectively capturing the most characteristic documents that best embody the cluster's semantic essence. By using documents with absolute topic assignment, we reduce semantic ambiguity and provide a precise representation of each cluster's core characteristics. This methodology both enhances the interpretability of the clustering results and offers a computationally efficient mechanism for extracting representative documents for each topic. A total of 159 documents with a probability of one were identified and subjected to

qualitative analysis to elucidate the semantic core of each cluster.

3.2.4. Thematic data coding process

We conducted an inductive analysis on the selected 159 representative documents (see Appendix A for a full list). These documents were selected as the most characteristic of each topic cluster, based on their highest probability scores from the topic-document probability matrix. Two researchers on the team independently conducted a close reading of each document to identify and code key insights. This manual analysis enabled a deep contextual understanding of the content within each topic cluster. We used a coding structure similar to that of Gioia et al. (2013) to organize our codes and develop concepts. First, we extracted our first-order codes by identifying the salient terms used in each document. Next, we grouped the codes into second-order themes based on commonality of topics. Finally, we aggregated these into nine dimensions, which form the major themes of extant ISRM literature. Two independent coders enacted the coding process, with consensus reached through detailed discussion between coders. Fig. 4 presents the data structure. In the next step, we organized these aggregate dimensions into research perspectives based on their theoretical and methodological similarities. The result is an integrated ISRM framework that captures a description of the ISRM research landscape.

3.2.5. Gap analysis and synthesis of findings

In the final step, we conducted an evolutionary synthesis and gap

Document	Topic Probability										
	Topic_11	Topic_12	Topic_13	Topic_14	Topic_15	Topic_16	Topic_17	Topic_18	Topic_19	Topic_20	Topic_21
Wang, Q., Ngai, E. W., Pienta, D., & Thatcher, J. B. (2023). Information technology innovativeness and data-breach risk: A longitudinal study. <i>Journal of Management Information Systems</i> , 40(4), 1139-1170.	0.00E-02	0.00E-02	1	0.00E-02	0.00E-02	0.00E-02	0.00E-02	0.00E-02	0.00E-02	7.56E-308	0.00E-02
Johnson, M. E. (2008). Information risk of inadvertent disclosure: An analysis of file-sharing risk in the financial supply chain. <i>Journal of Management Information Systems</i> , 25(2), 97-124.	5.57E-308	3.46E-308	0.00E-02	0.00E-02	8.72E-308	2.54E-308	4.55E-308	4.10E-308	1	0.00E-02	0.00E-02
Ebrahimi, M., Nunamaker Jr, J. F., & Chen, H. (2020). Semi-supervised cyber threat identification in dark net markets: A transductive and deep learning approach. <i>Journal of Management Information Systems</i> , 37(3), 694-722.	2.44E-308	2.74E-308	0.00E-02	0.00E-02	4.24E-308	0.00E-02	2.47E-308	1	4.43E-308	0.00E-02	2.70E-308
Sen, R., & Borte, S. (2015). Estimating the contextual risk of data breach: An empirical approach. <i>Journal of Management Information Systems</i> , 32(2), 314-341.	0.00E-02	0.00E-02	1	0.00E-02	0.00E-02	0.00E-02	0.00E-02	0.00E-02	0.00E-02	7.56E-308	0.00E-02
Anderson, C., Baskerville, R. L., & Kaul, M. (2017). Information security control theory: Achieving a sustainable reconciliation between sharing and protecting the privacy of information. <i>Journal of Management Information Systems</i> , 34(4), 1082-1112.	3.76E-308	1	0.00E-02	0.00E-02	9.93E-308	8.42E-308	5.61E-308	2.79E-308	4.45E-308	0.00E-02	0.00E-02
Oetzel, M. C., & Spiekermann, S. (2014). A systematic methodology for privacy impact assessments: a design science approach. <i>European Journal of Information Systems</i> , 23(2), 126-150.	1	3.44E-308	0.00E-02	0.00E-02	4.57E-308	2.56E-308	1.21E-307	0.00E-02	5.47E-308	0.00E-02	0.00E-02

Fig. 3. Snapshot of the topic-document probability matrix; cells with probability of one highlighted.

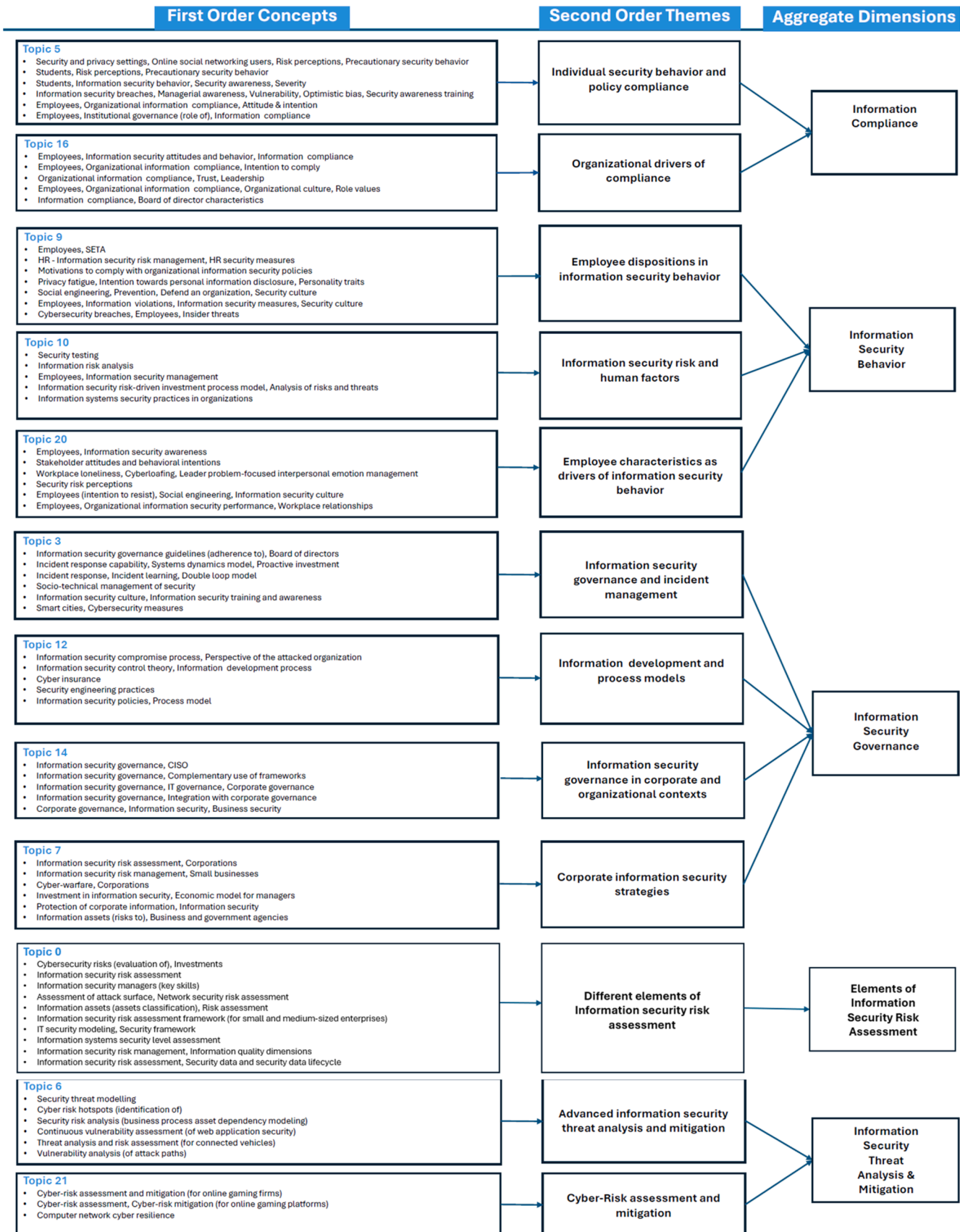


Fig. 4. Gioia data structure.

analysis of the various research perspectives emerging from our integrated ISRM framework. To trace how each perspective evolved over

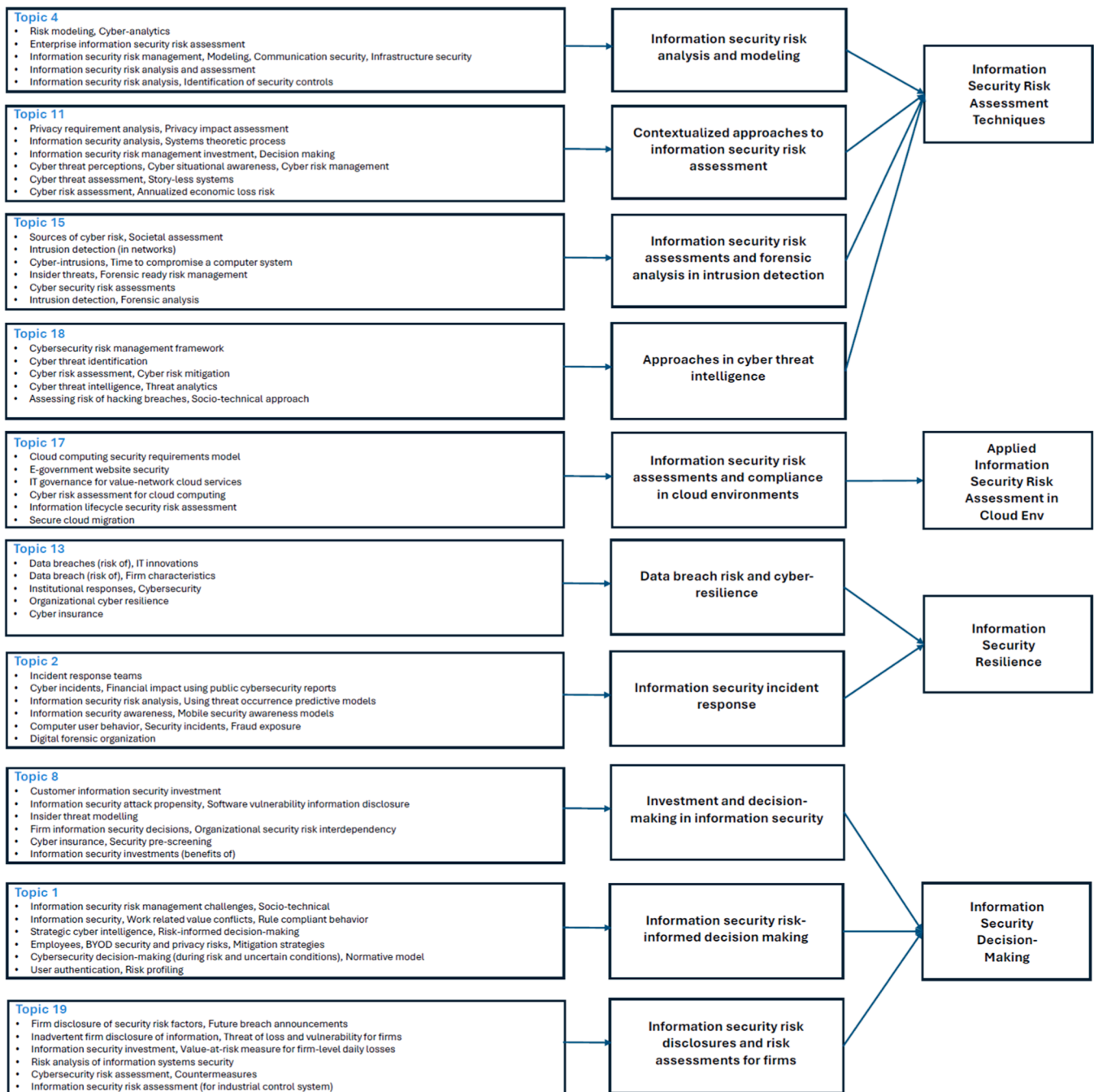


Fig. 4. (continued).

time, we selected 47 highly cited studies from the aggregate dimensions, with studies drawn from each defined epoch. These exemplar studies were entered into an Excel master file that captured the theory, method, and findings of each study. The research team then engaged in iterative discussions to make sense of these studies and their impact on the ISRM research landscape. The discussions allowed us to construct an evolutionary account of research within each perspective in our integrated ISRM framework. The insights emerging from this synthesis built on those generated through the development of the integrated ISRM framework. This combined understanding informed the gap analysis and helped us identify the research avenues which are presented in the Discussion section.

4. Findings

4.1. Impact analysis

We analyzed the trend in scholarly interest in ISRM over the past 26 years by examining publication patterns, with a focus on the annual number of articles from the top ten publication outlets. Fig. 5 highlights a peak in 2021, followed by a modest decline from 2021 (25 publications) to 2022 (16 publications) and a resurgence in 2024 (33 publications) and 2025 (45 publications). This trend underscores the field's increasing prominence and appeal in recent years. Additionally, Fig. 5 illustrates the steady growth in ISRM publications over time and the diversity of outlets, with "Computers & Security" emerging as the most prominent source, followed closely by "Information and Computer

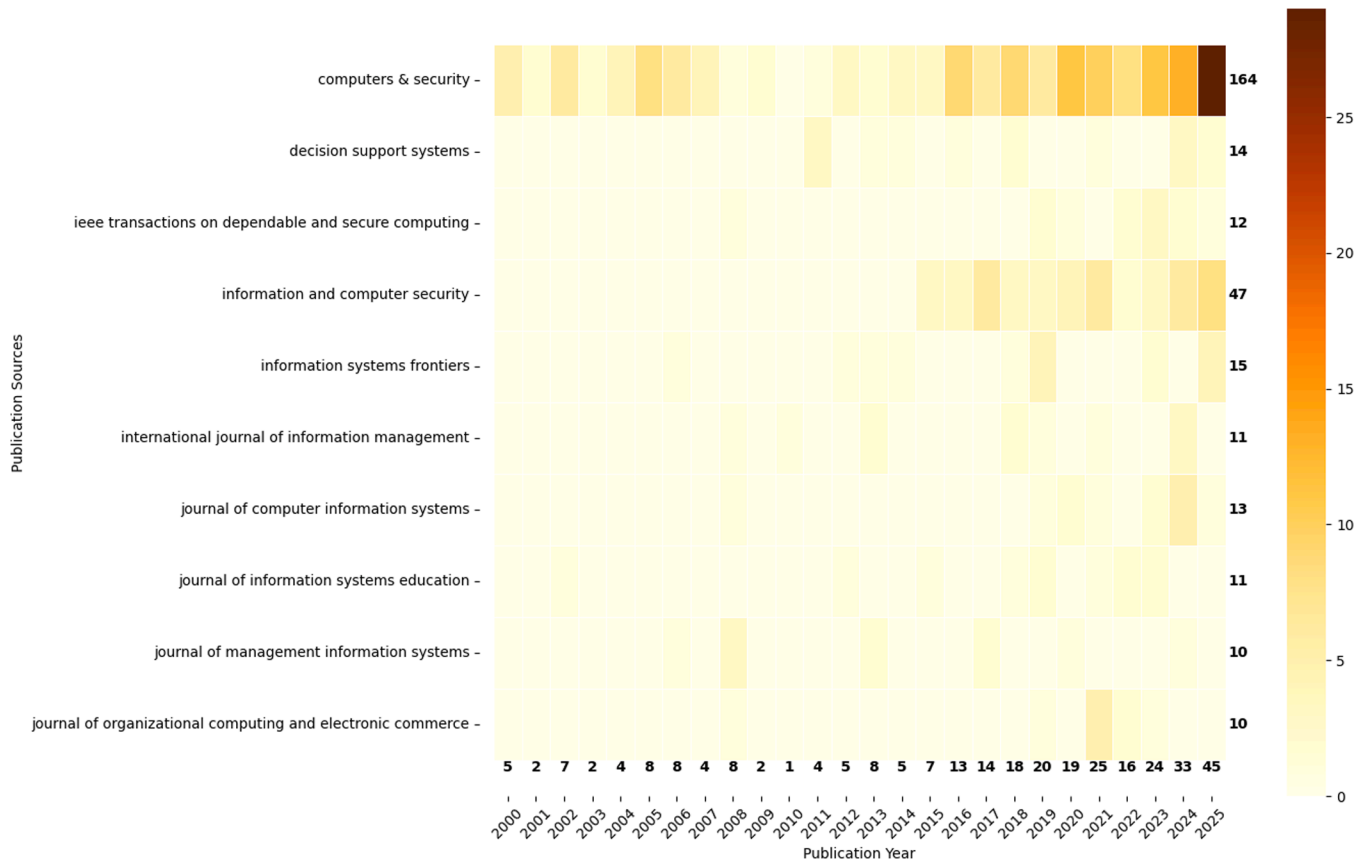


Fig. 5. Heatmap of top ten publication sources by year.

Security.”

4.2. Content analysis

The distribution of 623 articles across the 22 topic clusters (identified by their topic labels), along with their mapping to the key ISRM areas, is shown in Table 2. Articles that do not fall into any dominant topic are assigned the label -1. Table 2 shows that research related to ISRM processes are dominant in the literature, followed by research related to ISRM governance and strategy, respectively. This is not surprising given information security has not been a strategical focal point for many organizations (Proudfoot et al., 2023).

Fig. 6 provides a detailed visualization of evolving topic trends in ISRM research over the years, highlighting the intensity of publications across various topics. While earlier years show a concentrated focus on a few topics, such as Topic 1 and Topic 12, the period from 2014 onward reflects a broader dispersion of topics. Such dispersion suggests a shift toward addressing a variety of issues within ISRM, likely driven by the expanding scope of technological risks and organizational needs.

The methodological distribution of ISRM publications indicates a predominant reliance on quantitative methods (53.1%). Conceptual studies form the next largest category (18.2%), followed by smaller contributions from qualitative approaches (9.1%) and case studies (8.4%). Mixed-methods studies, representing 4.9%, reflect a growing interest in combining qualitative and quantitative insights. Other methodologies, including literature reviews, Delphi methods, and SLRs, make smaller yet meaningful contributions. This distribution highlights the field’s methodological focus while underscoring opportunities for greater diversification in future ISRM research.

Next, we looked at the NIST cybersecurity framework categories to align the analysis of ISRM studies with a practical and comprehensive risk management approach. The framework, comprising Identify,

Protect, Detect, Respond, and Recover categories, offers a structured lifecycle for managing cybersecurity risks and incidents. The histogram in Fig. 7 depicts the distribution of ISRM studies across these categories, based on our qualitative examination of each study to determine whether it aligns with one or more NIST categories. The results show a predominant focus on Identify and Protect categories. In contrast, fewer studies address Detect, Respond, and Recover categories, highlighting significant gaps in research related to incident detection, response strategies, and recovery planning. This imbalance suggests a strong focus on prevention but limited attention to post-incident phases, which are critical for minimizing the impact of cybersecurity breaches and ensuring business continuity. Future research could benefit from a more balanced approach that considers all aspects of the NIST framework in ISRM research.

4.3. An integrated framework of ISRM

Fig. 8 presents an integrated framework that captures the ISRM research landscape. The framework consolidates the emerging aggregate dimensions and groups them into three broader perspectives that emerged inductively from the qualitative coding: Technical, Socio-Behavioral, and Strategic & Governance. Overall, these perspectives reflect the main areas of emphasis in ISRM research, while also highlighting the growing recognition that information security is an organizational program that encompasses not only technical controls but also standardized processes (e.g., security and governance framework) and people dynamics (e.g., security trainings) (Crossler et al., 2013; Posthumus and von Solms, 2004; Dhillon and Backhouse, 2001). Additionally, the integrated framework is aligned with what Leidner (2018) described as an “assessing review,” one that consolidates existing ISRM scholarship rather than one that proposes new theoretical constructs. In other words, the framework provides a descriptive, evidence-based

Table 2

Topic distribution of articles.

Topic label	Second order theme	No. of articles	ISRM key area
0	Different elements of Information security risk assessment	102	ISRM Processes
2	Information security incident response	38	
4	Information security risk analysis and modeling	25	
6	Advanced information security threat analysis and mitigation	19	
11	Contextualized approaches to information security risk assessment	15	
13	Data breach risk and cyber-resilience	13	
15	Information security risk assessments and forensic analysis in intrusion detection	10	
17	Information security risk assessments and compliance in cloud environments	9	
18	Approaches in cyber threat intelligence	9	
21	Cyber-Risk assessment and mitigation	8	
3	Information security governance and incident management	26	ISRM Governance
5	Individual security behavior and policy compliance	19	
12	Information security policy development and process models	13	
14	Information security governance in corporate and organizational contexts	13	
16	Organizational drivers of security policy compliance	10	
19	Information security risk disclosures and risk assessments for firms	9	ISRM Strategy
1	Information security risk- informed decision making	54	
7	Corporate information security strategies	18	
8	Investment and decision-making in information security	16	
9	Employee dispositions in information security behavior	16	
10	Information security risk and human factors	16	
20	Employee characteristics as drivers of information security behavior	7	
–1	*	158	
	Total	623	

* Articles unassigned to any topic are assigned the label –1.

structure for interpreting how diverse ISRM streams fit together. Furthermore, the framework provides a way to identify research opportunities that sit across boundaries of the different perspectives.

To trace how ISRM has evolved within each perspective in depth, we curated exemplar studies for each perspective combining topic-central representative papers with highly cited contributions. We then structured the Technical, Socio-behavioral, and Strategic & Governance perspectives using a common three-epoch template (2000–2010, 2011–2019, 2020–present) and, within each epoch, systematically summarized the dominant focus of ISRM work, methods, theoretical lenses, and exemplar studies. The following sections describe the evolution of each perspective in detail.

4.3.1. Technical perspective

The technical perspective encompasses the methodologies, tools, models, and analytical mechanisms used to identify, analyze, model, and mitigate information security risks (Ebrahimi et al., 2020; Gerber and von Solms, 2005; Shameli-Sendi et al., 2016). Viewed historically, technical ISRM matures from early formal risk assessment and policy frameworks, through enterprise-level structuring methods, to AI-enabled threat intelligence and automation-oriented approaches, as summarized in Table 3.

4.3.1.1. Epoch 1 (2000 to 2010): foundations for technical ISRM. In the first epoch, the technical perspective on ISRM is expressed mainly through foundational work in formal risk assessment, policy, and economic decision models. In this period, foundational studies propose structured, quantitative approaches to risk assessment (Gerber and von Solms, 2001, 2005) and security policy (Rees et al., 2003), and develop economic decision models that quantify expected loss and support comparison of alternative security investments (Baker et al., 2007; Wang et al., 2008).

4.3.1.2. Epoch 2 (2011 to 2019): enterprise ISRM. Following the foundational period, technical ISRM consolidated into a formalized enterprise discipline. In this epoch, the focus shifted from isolated risk assessments toward the codification of ISRM through standardized frameworks, taxonomies, and ontological integrations that linked technical elements of information security with broader organizational governance. During this epoch, the technical perspective matures into structured, enterprise-level practice characterized by standardized risk and privacy methods (Oetzel and Spiekermann, 2014); operationalized situational awareness (Webb et al., 2014); taxonomy-driven method selection (Shameli-Sendi et al., 2016); ontology-driven integration of threat intelligence (Qamar et al., 2017); sectoral and contextual breach analytics linking organizational settings to risk (McLeod and Dolezel, 2018; Sen and Borle, 2015); and synthesized threat-modeling landscapes for proactive defense (Xiong and Lagerström, 2019). Collectively, these works mark a shift toward structured, integrated, and context-sensitive ISRM. Nevertheless, most contributions in this epoch remain conceptual, taxonomic, ontological, or review oriented, with limited evidence of large-scale empirical deployment, automation, or continuously adaptive real-time operation. Sectoral econometric studies add empirical links between organizational context and breach risk but do not close the deployment and automation gap.

4.3.1.3. Epoch 3 (2020 onward): intelligence-integrated and automation driven ISRM practice. From 2020 onward, the technical ISRM pivots to intelligence-integrated, automation-driven practice centered on AI and ML. Top-cited papers includes dark-web CTI and exploit-to-vulnerability linking (Ebrahimi et al., 2020; Samtani et al., 2022), transformer-based alignment of hacker activity to MITRE ATT&CK (Ampel et al., 2024), GPT-4 assisted drafting and evaluation of ransomware-focused GRC policies (McIntosh et al., 2023), and hybrid explainable AI linking phishing risk to recovery economics (Biswas et al., 2024). These studies embed machine intelligence into CTI, policy, and prioritization workflows, making intelligence integration and automation the defining features of post-2020 ISRM.

These epochs show a steady broadening of methodological sophistication in which the technical foundations of ISRM have expanded from early formal risk assessment and economic modeling to structured enterprise methods and, most recently, post-2020 intelligence-integrated and automation-driven security practices. At the same time, the literature reveals a divergence between increasingly complex AI-driven artefacts and verifiable empirical grounding: studies remain mostly conceptual and artifact centric, providing little evidence on the causal mechanisms through which automated interventions reduce risk in live organizational settings.

4.3.2. Socio-behavioral perspective

The socio-behavioral perspective foregrounds how human actors, work practices, and organizational cultures shape ISRM, treating risk management as emerging from interactions between employees, managers, and security artefacts (Bulgurcu et al., 2010; Spears and Barki, 2010). Across the epochs, socio-behavioral ISRM shifts from individual security behavior foundations to organizational drivers and culture, and most recently to leadership, relationships, and fatigue. Table 4 summarizes this progression.

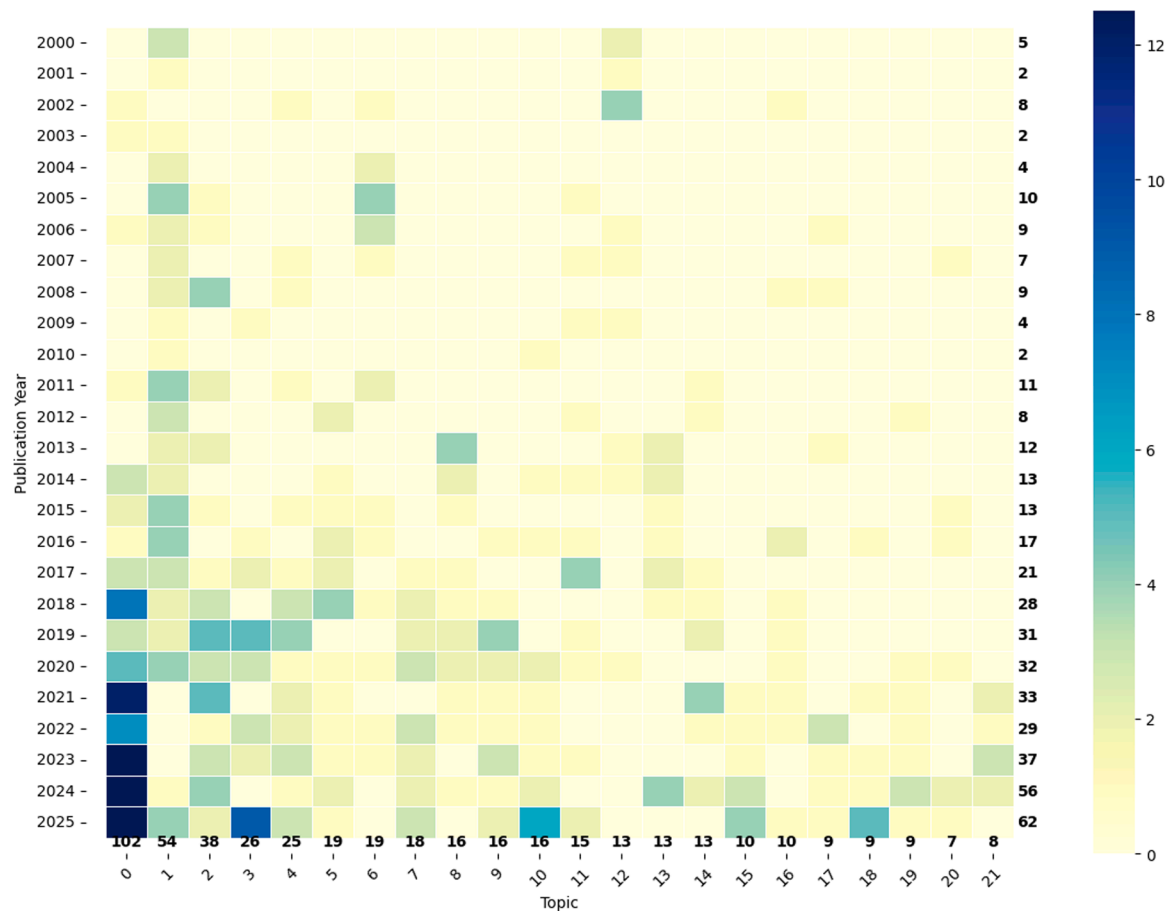


Fig. 6. Heatmap of topics by publication year.

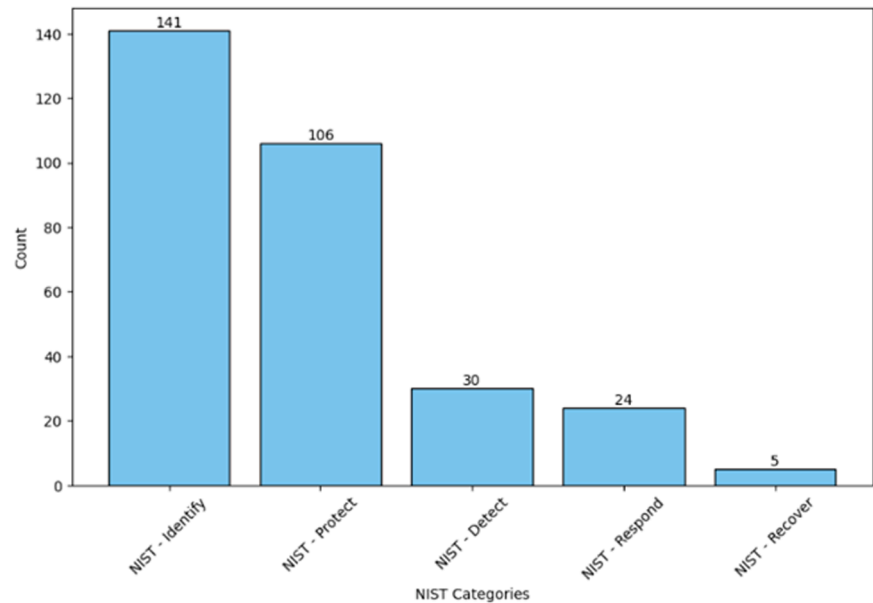


Fig. 7. Distribution of ISRM studies across NIST categories.

4.3.2.1. Epoch 1 (2000 to 2010): psychological foundations of individual security behavior. In the first epoch, socio-behavioral ISRM work centers on individual compliance and rational-choice explanations of security behavior. Early studies develop formal models of information security policy compliance in which employees’ intentions to comply are driven

by perceived benefits, costs, and sanctions, as well as beliefs about organizational support and justice (Bulgurcu et al., 2010; D’Arcy et al., 2009; Herath and Rao, 2009). These studies establish that security policies and controls cannot be understood purely as technical artefacts and that employees’ perceptions are central to risk outcomes. At the

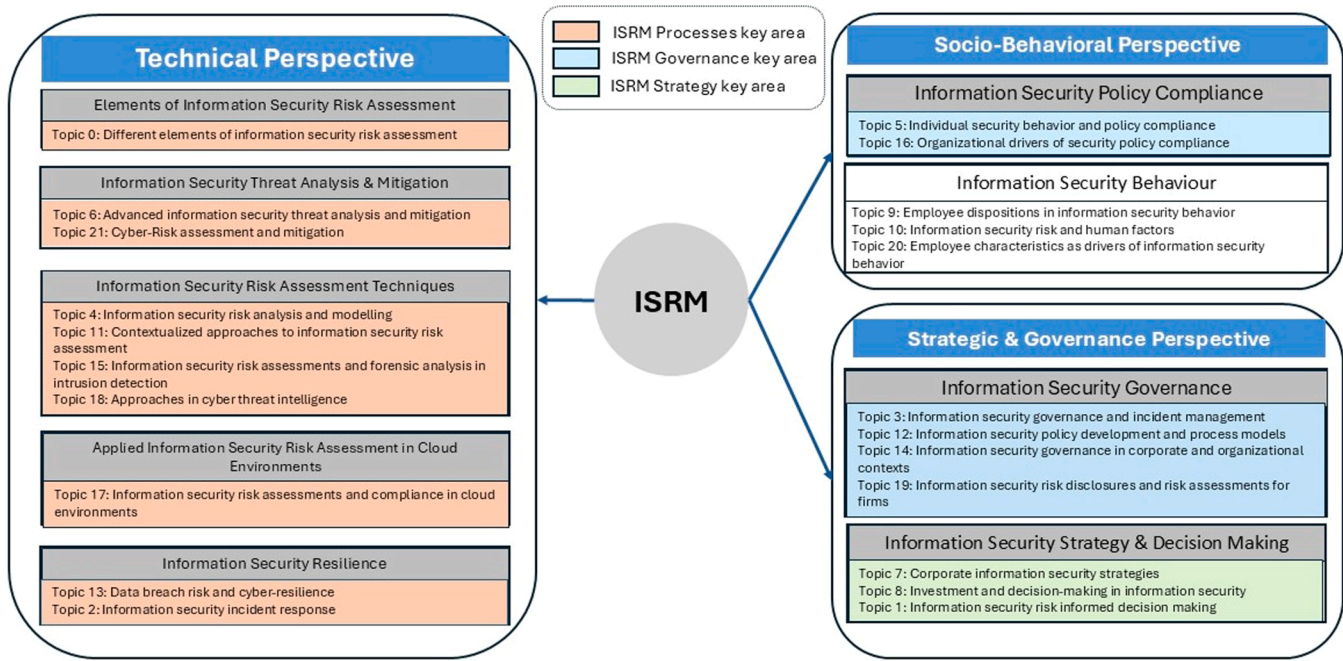


Fig. 8. An integrated framework of ISRM.

Table 3
Evolution of studies within the technical perspective.

Epoch	Focus	Methods	Theories	Exemplar Papers
2000–2010	Foundations for technical ISRM	Policy framework design; conceptual framing	-	(Rees et al., 2003; Gerber and von Solms, 2001, 2005; Baker et al., 2007; Bodin et al., 2018; Wang et al., 2008)
2011–2019	Enterprise structuring of ISRM	Design science; conceptual model with case refinement; taxonomy/survey; ontology engineering; econometrics; systematic review	Routine Activity Theory; Institutional theory; Opportunity theory of crime; Systems theory	(Oetzel and Spiekermann, 2014; Webb et al., 2014; Shamel-Sendi et al., 2016; Qamar et al., 2017; Xiong and Lagerstrom, 2019)
2020 onward	Intelligence-integrated and automation driven ISRM practice	Semi-supervised and deep learning; computational design science; fuzzy MCDM; LLMs; XAI	Organizational learning; Game theory; Computational design science	(Ahmad et al., 2020; Shin and Lowry, 2020; Ebrahimi et al., 2020; Samtani et al., 2022; McIntosh et al., 2023; Biswas et al., 2024; Ampel et al., 2024)

same time, socio-behavioral phenomena remain analytically decoupled from concrete technical controls and governance arrangements: models rarely specify how technical aspects configure the situations in which individuals decide whether to comply, report, or circumvent controls, instead treating “policy”, “countermeasures”, and “participation” as abstract variables in behavioral equations (Ransbotham and Mitra, 2009; Spears and Barki, 2010).

4.3.2.2. Epoch 2 (2011 to 2019): social and organizational drivers of individual security behavior. From 2011 to 2019, socio-behavioral ISRM pivoted from narrow individual-intention models to accounts that foreground risk perceptions, social bonds, culture, and institutional context. Representative work includes social-bond and risk-benefit models of policy compliance and insider behavior (Farahmand and Spafford, 2013; Lowry and Moody, 2015; Safa et al., 2016), cyber-risk perception studies (van Schaik et al., 2017), cultural and leadership models (Veiga and Eloff, 2010; Flores et al., 2014), and institutional accounts showing governance structures (Hina et al., 2019). The studies in this epoch portray secure behaviors as jointly shaped by risk perceptions, organizational culture, leadership, and institutional governance rather than by individual beliefs alone. Overall, work in this epoch successfully broadens the focus from individual beliefs to organizational conditions. Empirically, the heavy reliance on self-report cross-sectional surveys and structural model testing means we learn

far more about covariance structures among attitudes and intentions than about actual reporting, access, or escalation behaviors and how they unfold over time. This creates a persistent tension in the socio-behavioral literature: theories and constructs invoke rich organizational and governance contexts, but the pathways from these organizational drivers to operational risk outcomes remain largely assumed rather than demonstrated.

4.3.2.3. Epoch 3 (2020 onward): leadership and relational factors in building resilient security culture. From 2020 onward, the socio-behavioral perspective on ISRM has expanded beyond static models of compliance to examine the dynamic interplay of leadership, relational trust, and psychological fatigue. One strand studies how employees’ security policy compliance and the emergence of an information security policy compliance culture are jointly shaped by leadership, supportive information security culture, trust, role values, and the combination of organizational and individual behavioral factors (Koohang et al., 2020; Nord et al., 2022). Other studies extend this view by showing that the quality of IS–user relationships and the extent to which supervisors embody organizational security values foster security-related organizational citizenship behaviors (Davis et al., 2024; Turel et al., 2020). Fatigue-focused work conceptualizes security fatigue as a form of work disengagement that manifests as weariness or aversion to security-related tasks or advice when employees are repeatedly

Table 4

Evolution of studies within the socio-behavioral perspective.

Epoch	Focus	Methods	Theories	Exemplar papers
2000–2010	Foundations of individual security behavior, policy compliance, and early security culture in ISRM	Conceptual risk and process models; case studies; cross-sectional surveys; structural equation modelling and regression	Theory of planned behavior; Deterrence theory; Protection motivation theory	(D'Arcy et al., 2009; Herath and Rao, 2009; Bulgurcu et al., 2010; Spears and Barki, 2010)
2011–2019	Organizational drivers, risk perceptions, and employee motivational dispositions in security behavior and culture	Large-scale cross-sectional surveys; structural equation modelling and regression; quantitative behavioral online studies; case studies	Protection motivation theory; Theory of planned behavior; Social bond theory; Organizational control theory; Reactance theory; Prospect theory; Agency theory	(Farahmand and Spafford, 2013; Lowry and Moody, 2015; Da Veiga and Martins, 2015; Safa et al., 2016; Rocha Flores et al., 2014; van Schaik et al., 2017; Hina et al., 2019)
2020 onward	Leadership, culture, relationships, and fatigue in security behavior	Large-sample cross-sectional surveys; structural models; quantitative studies; case studies	Event system theory; Social exchange theory; Role theory; Organizational citizenship behavior; Social bond theory; Accountability theory; Risk homeostasis theory; Unified model of information security policy compliance; Attribution theory; Belief reinforcement model; Elaboration likelihood model; Ego depletion theory	(Koochang et al., 2020; Turel et al., 2020; Nord et al., 2022; Bhana and Ophoff, 2023; Davis et al., 2024)

exposed to cybersecurity demands and training (Bhana and Ophoff, 2023; Reeves et al., 2021). These studies reframe this epoch as one in which security culture is actively built and maintained through leadership behavior, supportive culture, trust and role values, while cumulative security demands and repeated security interventions can generate security fatigue that erodes engagement and must be treated as constraints on socio-behavioral models of security behavior.

Across the three epochs, socio-behavioral ISRM evolves from early rational choice models to organizational accounts of culture and risk perceptions, and most recently to socio-technical treatments. Yet across this trajectory, empirical evidence remains skewed toward self-report cross-sectional surveys and attitudinal covariance structures, with socio behavioral constructs often specified as broad latent variables that

are only weakly tied to concrete controls, governance mechanisms, or sustained changes in reporting, access, and escalation behavior over time. The socio-behavioral perspective therefore exposes both the growing recognition that human factors are central to ISRM outcomes and the unresolved need to integrate these constructs with concrete ISRM processes that sit at the intersection of technical controls and governance arrangements.

4.3.3. Strategic and governance perspective

The strategic and governance perspective examines how executives, boards, and formal governance mechanisms underlying ISRM and position information security within corporate governance and business objectives (Posthumus and von Solms, 2004; Veiga and Eloff, 2007). It focuses on how responsibilities are allocated, how policies, awareness programs, and security culture are governed, and how security investment and disclosure are shaped by economic and institutional pressures (Chen et al., 2011; Knapp et al., 2009a; Kruger and Kearney, 2006; Wang et al., 2013). Table 5 summarizes how this perspective evolves across epochs.

4.3.3.1. Epoch 1 (2000 to 2010): foundational governance frameworks and policy process models. In the first epoch, strategic and governance-oriented ISRM work concentrates on building foundational frameworks, checklists, and process models that reframe information security as a core corporate governance responsibility (Posthumus and von Solms, 2004; Veiga and Eloff, 2007; Von Solms and von Solms, 2006). These studies synthesize components from standards such as COBIT and ISO into holistic models that specify management responsibilities, key processes, and critical success factors. Other prominent work in this epoch develops organizational policy process models and awareness measurement instruments, positioning information security policy and awareness as central mechanisms through which governance frameworks are operationalized (Knapp et al., 2009; Kruger and Kearney, 2006).

4.3.3.2. Epoch 2 (2011 to 2019): ISRM as a risk-informed decision-making process. In the second epoch, strategic and governance-oriented ISRM shifts from prescribing static governance frameworks to treating ISRM as a risk-informed decision-making process. Quantitative decision-support and economic models of security investment (Chen et al., 2011; Rees et al., 2011), policy life-cycle models (Flowerday and Tuyikeze, 2016), strategic cyber intelligence work (Borum et al., 2015), and analyses of cybersecurity risk factor disclosures (Wang et al., 2013) together push ISRM beyond normative frameworks toward explicit risk-informed governance.

4.3.3.3. Epoch 3 (2020 onward): ISRM in digital ecosystems and board-level oversight. In the third epoch, strategic- and governance-oriented ISRM research examines cyber risk governance across interconnected infrastructures and organizational fields. This epoch makes progress in scaling the strategic and governance perspective to digital ecosystems and critical infrastructures (Choo et al., 2021; Gunes et al., 2021). Information security governance reviews trace how security has shifted from a narrow technical concern to a strategic “boardroom” issue (Schinagl et al., 2022), and to factors that drive but also constrain directors’ engagement with cybersecurity oversight (Gale et al., 2022).

The strategic and governance perspective evolves from normative, standard-driven frameworks and policy processes to risk-informed economic decision making and, most recently, to governance of cyber risk in digital ecosystems and at board level. Yet across this evolution, evidence remains fragmented by layer, sector, and method: many studies center on individual frameworks, single firms, or specific governance mechanisms, offer limited cross-context validation, and rarely trace how board and executive decisions shape technical controls and day-to-day security behavior. This perspective therefore exposes both the growing

Table 5
Evolution of studies within the strategic and governance perspective.

Epoch	Focus	Methods	Theories	Exemplar papers
Epoch 1 (2000–2010)	Foundational governance frameworks and policy process models	Conceptual; organizational level process models; prototype development;	Normative governance and management control perspectives grounded in standards such as COBIT and ISO	Von Solms and von Solms, 2006; Posthumus and von Solms, 2004; Kruger and Kearney, 2006; Da Veiga and Martins, 2015; Veiga and Eloff, 2007; Knapp et al., 2009
Epoch 2 (2011–2019)	Risk informed decision making	Analytical and economic risk modeling; case studies; survey-based work; quantitative analyses; conceptual economic frameworks	Economic and decision support views; Institutional and signaling theories	Chen et al., 2011; Wang et al., 2013; Flowerday and Tuyikeze, 2016
Epoch 3 (2020–present)	Governance and risk management scaled to digital ecosystems, critical infrastructures, and board-level oversight	Case-based cyber-risk assessments, systematic literature reviews, large-sample econometric studies, game-theoretic/analytical models	Game theory and principal-agent models; Resource-based view	Schlingel and Shahim, 2022; Gunes et al., 2021; Choo et al., 2021; Gale et al., 2022

institutionalization of ISRM as a core component of corporate governance and the unresolved need to connect it more tightly to operational controls and socio-behavioral processes.

5. Discussion

Through a combination of ML techniques and qualitative coding, we identify 22 themes that reflect a comprehensive view of ISRM. These are further aggregated into nine overarching dimensions, which we organize into an integrated framework encompassing Technical, Socio-Behavioral, and Strategic & Governance perspectives. By aligning these perspectives with the ISRM key areas of Processes, Governance, and Strategy, this multidimensional framework highlights how technical mechanisms, human factors, and oversight structures must interlock to form a robust defense against evolving threats. Effective ISRM cannot rely on a single perspective. Even advanced technical controls will falter without sound governance practices and a workforce aligned with firm objectives. This observation underscores the importance of exploring the overlaps and interdependencies among these perspectives for a truly integrated approach. By viewing ISRM as a system that integrates technology, people, and executive direction, our framework both illuminates existing research gaps and reveals new opportunities for future investigations.

We use this framework as a lens to interpret our results and to identify three research gaps in the extant ISRM literature. First, mapping the literature to the NIST functions shows that Identify and Protect dominate while Detect, Respond, and Recover are sparsely studied, leaving gaps in incident detection, response, and recovery planning and revealing a prevention-heavy field that is thin on post-incident capabilities essential for loss mitigation and business continuity. Second, coverage across the three ISRM key areas is unbalanced: process-oriented work on risk assessment and control design dominates (Topics 0, 4, 11, 15, 18), while governance and especially strategy, such as board oversight, risk sharing, and disclosure, receive much less empirical attention. Third, our integrated framework shows that socio-behavioral themes form a cross-cutting perspective, yet existing studies tend to treat human, technical, and governance issues in separate streams, with little work on how they interact in day-to-day work practices. Reflecting on these research gaps, we suggest three research avenues for future studies, discussed below.

5.1. Research avenue 1: strengthening post-incident ISRM capabilities

Research avenue 1 focuses on developing integrated post-incident ISRM capabilities that span the NIST Detect, Respond and Recover functions and connect technical controls with human and governance arrangements within the integrated framework in Fig. 8. From a theoretical standpoint, these post-incident capabilities are prototypical dynamic capabilities and sources of organizational resilience (Duchek, 2020; Teece et al., 1997). In the NIST Cybersecurity Framework and related guidance, Detect, Respond, and Recover are positioned as core functions alongside Identify and Protect and as essential, resource-intensive programmatic capabilities for sustaining continuity of critical services and managing incidents across their lifecycle (Cichonski et al., 2012). Empirical studies describe incident response teams as critical security functions whose coordination of analysis, communication, and remediation shapes the timeliness and cost effectiveness of incident handling and supports the broader security function (Ahmad et al., 2020; Van der Kleij et al., 2017). Recent work highlights the need for agile, data-enabled incident response capabilities to handle diverse and fast-evolving cyber threats (Naseer et al., 2023). Systematic reviews argue that post-incident processes are pivotal for strengthening controls and reducing the recurrence and impact of future incidents, yet are still not leveraged systematically in many organizations (Patterson et al., 2023). Building on these developments, we position post-incident ISRM as an avenue for future studies to extend organizational resilience

theorizing in cybersecurity.

Qualitative synthesis of representative post-incident studies indicates that loss is realized through prolonged dwell times, delayed containment, coordination breakdowns, and weak learning mechanisms after incidents (Ahmad et al., 2020; Sen and Borle, 2015). Viewed through our integrated technical, socio-behavioral, and governance framework, two key gaps emerged. First, post-incident capabilities are usually designed and evaluated as technical functions, with limited integration of human practices and governance. Second, there is limited understanding of how structured, cross-functional incident review and learning processes reshape organizational risk posture over time. Table 6 links each gap to suggested theoretical lenses and a guiding research question; the following subsections elaborate these two gaps.

First, existing research on post incident ISRM portrays incident response as a largely technical security function and has begun to examine how big data analytics enables agile response to diverse cyber threats (Ahmad et al., 2020; Naseer et al., 2023). However, much of this work still conceptualizes detection, response, and recovery in predominantly technical terms and treats human practices and governance as background conditions rather than integral parts of the capability. From a dynamic capabilities and organizational resilience perspective, this narrow focus obscures the fact that effective post-incident ISRM depends on cross-functional sensing, responding, and reconfiguring capabilities that jointly couple analytics, frontline behavior, and governance structures. Socio-technical systems theory further suggests that the performance of post-incident capabilities emerges from interactions between technical artifacts, work practices, and institutional arrangements rather than from technical components alone. This motivates our first research question (Table 6, RQ1), which asks how jointly configured detection, response, and recovery capabilities across technical, socio-behavioral, and governance layers influence post-incident ISRM performance.

Second, although incident reviews are widely recommended in standards and practitioner guidance as well as performed by organizations to reflect on causes and responses (He and Johnson, 2017; Paterson et al., 2023), research provides only a fragmented view of how structured, cross-functional review and learning processes transform incidents into durable changes in organizational routines and controls. Few ISRM studies analyze incident reviews through the lens of organizational learning theory (Argyris and Schön, 1997), or examine how review composition, artifacts, and follow-up processes shape the depth and persistence of learning. There is also limited longitudinal evidence on how patterns of incident review affect the recurrence of similar incidents. Addressing these gaps requires theory-driven studies of incident review practices that explicitly link the content and process of reviews, combining technical evidence, behavioral analysis, and managerial decision making, to changes in control configurations and subsequent

incident patterns. This is captured in our second research question (Table 6, RQ2).

5.2. Research avenue 2: translating technical risk into board-level information

Building on the overlap between the technical and the strategic and governance layers in our integrated framework, Research Avenue 2 examines how technical risk information is transformed into board-grade risk assessments and risk-sharing arrangements that enable informed, enterprise-level cyber risk oversight. From a theoretical standpoint, this translation problem is an organizational information-processing challenge: boards operate under high uncertainty and limited attention, so the design of cyber risk representations and reporting channels must align information-processing capacity with decision requirements, as argued in classic information-processing theories (Daft and Lengel, 1986; Tushman and Nadler, 1978). Extant literature contains myriad examples of how boards are struggling with the continuously evolving cyber threats: directors remain uncertain about their cybersecurity duties, and often rely heavily on a single board member or external expert with cyber experience (Gale et al., 2022); many boards view cybersecurity as a technical rather than a strategic business issue (McFadzean et al., 2007); and senior leaders openly describe themselves as muddling through cybersecurity (Abraham et al., 2019). Not surprisingly, practitioner literature increasingly highlights the need for concise, aggregated metrics that translate technical posture, control effectiveness, and incident exposure into business-relevant indicators for better decision making (Bitsight, 2023; ISACA, 2021).

Our synthesis reveals a substantial body of work on risk-informed decision making and quantitative risk models (M'manga et al., 2019; Rees et al., 2011), but far fewer studies on the concrete reporting tools and materials that allow boards and risk committees to effectively assess cyber risk (Ahmad et al., 2020; Baskerville et al., 2022). Most empirical studies still treat technical risk, human factors, and governance choices separately, with limited work on integrated decision-support structures (Mukhopadhyay et al., 2019; Woods, 2023). Viewed through our integrated framework, these patterns point to two gaps in the current literature: limited understanding of how technical, behavioral, and strategic information are integrated into board-level decision making; and sparse work linking internal cyber risk experience to external disclosure and market learning. Table 7 summarizes these two gaps, the theoretical lenses we propose to address each, and illustrative research questions that follow from our analysis.

First, there is a lack of integration of information across perspectives to support board-level decision making. Technical studies excel with quantitative cyber risk and information security investment models that estimate expected losses, optimize security controls, and analyze cyber insurance and other risk-sharing decisions to evaluate alternative risk treatments (Baker et al., 2007; Mukhopadhyay et al., 2019). Governance-oriented studies scrutinize how directors perceive

Table 6
Future research directions for integrated post-incident ISRM capabilities.

Gaps in the research	Suggested theories	Research questions
Post-incident capabilities are designed and evaluated mainly as technical functions, with limited integration of human practices and governance mechanisms	Dynamic capabilities; Organizational resilience; Socio-technical systems theory	RQ1: How do jointly configured detection, response, and recovery capabilities across technical, socio-behavioral, and governance layers influence post-incident ISRM performance?
Limited understanding of how structured, cross-functional incident review and learning processes reshape organizational risk posture over time	Organizational learning theory	RQ2: How do incident review practices that combine technical evidence, behavioral analysis, and management decision making affect recurrence of similar incidents?

Table 7
Future research directions for integrated technical-to-board risk translation.

Gaps in the research	Suggested theories	Research questions
Limited understanding of how technical, behavioral, and strategic information is integrated into board-level decision-making	Information processing theory	RQ1: How do different designs of integrated cyber-risk reporting influence board decisions?
Sparse work linking internal cyber-risk experience to cyber-risk disclosure and the subsequent market effects	Signaling theory; Legitimacy theory	RQ2: How do internal indicators of technical incidents influence the timing, specificity, and market effects of cybersecurity risk disclosures?

information security, the drivers and barriers of board engagement, and the structural arrangements through which boards oversee cybersecurity (Gale et al., 2022; Proudfoot et al., 2023). Practitioner guidance on cyber risk dashboards and board reporting goes further by proposing dashboards that aggregate technical posture, incident trends, and business impact for nontechnical audiences (PwC, 2025). Yet, from an organizational information processing perspective, the representations and communication channels through which cyber risk information reaches the board remain theoretically underspecified and empirically under studied. This motivates our first research question (Table 7, RQ1), which asks how different designs of integrated board-level cyber risk reporting that combine technical, socio-behavioral, and strategic indicators shape board decisions.

Second, research only partially connects firms’ internal cyber risk experience to their external cybersecurity disclosures and the ways in which capital markets interpret those disclosures. Prior studies show that cybersecurity risk disclosure is associated with changes in stakeholder trust and firm value (Bansal and Axelton, 2024; Fortin and Héroux, 2023). Consequently, studies have examined the drivers that determine the level of cybersecurity risk disclosure. Studies that utilize signaling theories (Spence, 1973) argue for more extensive or specific disclosure as a way for better positioning firms to communicate risk management quality to investors, and studies using legitimacy theories (Suchman, 1995) emphasize how public scrutiny and institutional expectations drive firms to expand cybersecurity risk disclosure to maintain legitimacy with key stakeholders (Cheng et al., 2022; D’Arcy and Basoglu, 2022). However, little is known about how internal indicators of cyber incidents are aggregated into decisions about disclosure timing and specificity, and how those disclosure choices shape market reactions. Recent evidence posits that prior cyber incidents, public and institutional pressure, and board-level characteristics all affect the likelihood and extent of such cybersecurity risk disclosure (D’Arcy and Basoglu, 2022). These developments motivate our second research question which suggests future studies to examine the relationship between internal cyber incidents and external cybersecurity risk disclosure (Table 7, RQ2).

5.3. Research avenue 3: strengthening human-centered ISRM

The human element is central to cyber risk, with roughly sixty percent of security incidents estimated to come from human actions and errors (Verizon, 2025). We therefore argue that a human-centered ISRM is an important research avenue that transcends all three perspectives in effectively managing information security risk. From a theoretical standpoint, this avenue sits at the intersection of three perspectives: Behavioral security models, which show that employees’ beliefs about risks and sanctions and security awareness shape compliance, misuse, and participation in risk management (Bulgurcu et al., 2010; D’Arcy et al., 2009; Vance et al., 2012). Socio-technical perspectives that conceptualize security as an emergent property of interactions among people, technologies, and organizational arrangements (Dhillon and Backhouse, 2001; Spears and Barki, 2010). And governance research which demonstrates that effectiveness of policies, oversight structures, and risk committees depend on sustained behavioral alignment with the organization’s risk appetite and informal organizational norms (Chen et al., 2015; Flores et al., 2014).

Our synthesis of human-centered ISRM research highlights two consistent patterns. First, behavioral studies have built a substantial evidence base on policy compliance intentions, deterrence beliefs, and security awareness, typically modeled at the individual level (Bulgurcu et al., 2010; D’Arcy et al., 2009; Hina et al., 2019). Second, methodological contributions and studies of training indicate that the evidence base is still heavily skewed toward cross-sectional surveys and short-term interventions, with only a small but growing number of longitudinal designs. These patterns reveal two gaps on the human side of ISRM: reliance on self-reported attitudes and intentions with limited

linkage to operational behavior and specific technical and governance arrangements; and sparse knowledge about the temporal dynamics of secure behavior, fatigue, and reinforcement. Table 8 summarizes these gaps, the theoretical lenses we propose to address each, and the research questions that follow from our analysis.

Most ISRM studies operationalize security behaviors through self-reported attitudes, intentions, or broad behavioral indices (Bulgurcu et al., 2010; Herath and Rao, 2009; Ifinedo, 2012). Studies of information security culture and SETA programs similarly foreground perceptions and self-reported behavior change (Da Veiga and Martins, 2015; Kruger and Kearney, 2006; Veiga and Eloff, 2007). However, the literature says little about how these psychological and cultural drivers play out at specific control points in live systems where combinations of technical features, behavioral interventions, and governance mechanisms shape what users do. Viewed through activity theory, socio-technical systems theory, and affordance theory, these control points can be seen as socio-technical activities in which human subjects, tools, rules, and division of labor are configured, and in which specific elements afford or hinder security actions. This imbalance motivates our first research question (Table 8, RQ1), which asks how specific combinations of technical features, behavioral interventions, and governance mechanisms influence actual security behavior.

Extant ISRM work on training and temporal dynamics of behavior is still limited, but it offers initial insight into how employees experience security education events and highlights the need to study how security-related cognitions evolve over time (Cram et al., 2024; Hu et al., 2022). Recent studies on security fatigue and overload show that cumulative exposure to security prompts and requirements can undermine engagement (Mizrak et al., 2025; Reeves et al., 2021). Viewed through learning-curve and habit-formation perspectives, this sparse and fragmented evidence leaves a clear gap: we know that repetition and practice matter for skill and habit acquisition, but we have little evidence on how different cadences and mixes of training, in-context nudges, and managerial follow-up shape the durability of secure behaviors in day-to-day work. This motivates our second research question (Table 8, RQ2).

5.4. Limitations

This study is not without limitations. First, the data corpus is bounded by the choice of data sources and inclusion criteria. These decisions improve quality control but risk under-representing relevant ISRM work published in other disciplines, non-English venues, practitioner reports, and standards documents, which may bias the picture of the field toward mainstream information systems and security outlets.

Second, all computational analyses are based on article abstracts rather than full texts. While abstracts provide consistent, comparable summaries at scale, they compress theoretical arguments,

Table 8
Future research directions for strengthening socio-behavioral integration in ISRM.

Gaps in the research	Suggested theories	Research questions
Over-reliance on self-reported attitudes with limited linkage to technical and governance mechanisms	Activity theory; Socio technical systems theory; Affordance theory	RQ1: How do integrated technical, behavioral, and governance arrangements at key control touchpoints influence actual security behavior?
Sparse knowledge about cyber-fatigue, decay of secure behaviors, and effective reinforcement strategies	Learning curves; Habit-formation theory	RQ2: How do different reinforcement cadences for training and in-context nudges, integrated with technical controls and managerial follow-up, affect the durability of secure behaviors?

methodological nuance, and contextual details. As a result, some topics may appear more homogeneous than they are in the underlying studies, and niche themes that are not foregrounded in abstracts may be under-detected by the embedding and clustering pipeline. This limitation is partially mitigated, but not removed, by the subsequent qualitative analysis of a subset of papers.

Third, the qualitative synthesis and integrated framework are based on reading the abstracts of 159 representative articles. Although this procedure enhances interpretability and depth, it remains interpretive: emphasis is inevitably placed on themes that are salient in the representative articles. The framework should therefore be viewed as a structured synthesis rather than an exhaustive theory of ISRM.

6. Conclusion

Prior literature reviews on ISRM have a fragmented focus across all three key areas of ISRM and utilized methodologies that have challenges in conducting large-scale review (i.e., lack of scalability). To address those limitations, this study employs an innovative mixed-methods approach for SLR, demonstrating how computational techniques can

be paired with qualitative analysis to extract meaningful insights from large datasets. By integrating the often-fragmented technical, socio-behavioral, and governance perspectives, the study unifies diverse strands of ISRM research and propose an integrated framework that can serve as a robust foundation for future exploration of these dimensions. We hope the review has provided meaningful insights and notable future research avenues to information security scholars.

CRedit authorship contribution statement

Biju B Varghese: Writing – review & editing, Writing – original draft, Methodology, Conceptualization. **Quang Neo Bui:** Writing – review & editing, Writing – original draft, Supervision, Methodology.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

APPENDIX A. Documents used for thematic data coding

I = NIST Identify; P = NIST Protect; D = NIST Detect; Rp = NIST Respond; Rc = NIST Recover

Topic	Paper	Journal	Year	Method	I	P	D	Rp	Rc
0	Solic et al., 2015	computers & security	2015	Case Study	Yes	Yes	No	No	No
0	Lo and Chen, 2012	expert systems with applications	2012	Quantitative	Yes	Yes	No	No	No
0	Chen et al., 2019	journal of global information management	2015	Delphi method	Yes	Yes	No	No	No
0	Shameli-Sendi et al., 2016	computers & security	2016	Literature review	Yes	Yes	Yes	Yes	No
0	Shamala et al., 2017	journal of information security and applications	2017	Quantitative	Yes	Yes	No	No	No
0	Bopche and Mehtre, 2017	computers & security	2017	Quantitative	Yes	No	Yes	No	No
0	Haqaf and Koyuncu, 2018	international journal of information management	2018	Delphi method	Yes	Yes	No	No	No
0	Norta et al., 2019	computers & security	2019	Conceptual	Yes	Yes	No	No	No
0	Xiong and Lagerström, 2019	computers & security	2019	Literature review	Yes	Yes	No	No	No
0	Shameli-Sendi, 2020	journal of information security and applications	2020	Conceptual	Yes	Yes	No	No	No
0	Schmitz and Pape, 2020	computers & security	2020	Quantitative	Yes	Yes	No	No	No
0	Villalón-Fonseca, 2022	computers & security	2022	Conceptual	Yes	Yes	No	No	No
0	Deane et al., 2023	journal of computer information systems	2023	Quantitative	Yes	No	No	No	No
0	Paparis et al., 2025	journal of information security and applications	2025	Quantitative	Yes	Yes	Yes	Yes	No
0	Parente et al., 2025	journal of information security and applications	2025	Quantitative	Yes	Yes	Yes	No	No
0	Kurt et al., 2025	computers & security	2025	Quantitative	Yes	Yes	No	No	No
0	Nganga et al., 2025	computers & security	2025	Mixed Methods	Yes	Yes	Yes	No	No
1	Faily, 2015	information and computer security	2015	Case Study	Yes	No	No	No	No
1	Borum et al., 2015	information and computer security	2015	Conceptual	Yes	Yes	Yes	No	No
1	Butler and Butler, 2015	information and computer security	2015	Quantitative	Yes	Yes	No	No	No
1	Bello et al., 2017	information and computer security	2017	Case Study	Yes	Yes	No	No	No
1	Bergström et al., 2020	information and computer security	2019	Qualitative	Yes	No	Yes	Yes	No
1	Meland et al., 2019	information and computer security	2019	Quantitative	Yes	Yes	No	Yes	No
1	M'manga et al., 2019	information and computer security	2019	Qualitative	Yes	No	No	No	No
1	Gyllenstein et al., 2021	information and computer security	2022	Mixed Methods	Yes	No	Yes	Yes	No
2	Malandrín and Carvalho, 2013	pacific asia journal of the association for information systems	2013	Conceptual	Yes	Yes	No	No	No
2	López et al., 2019	computers & security	2019	Quantitative	Yes	No	Yes	No	No
2	Tubío Figueira et al., 2020	computers & security	2020	Quantitative	Yes	Yes	No	No	No
2	Franco et al., 2024	computers & security	2024	Quantitative	Yes	No	No	No	No
2	Ahmad et al., 2020	computers & Security	2020	Conceptual	Yes	Yes	Yes	Yes	Yes
3	Qian et al., 2012	computers & Security	2012	Quantitative	Yes	Yes	No	Yes	No
3	Da Veiga and Martins, 2015	computers & security	2015	Case Study	Yes	Yes	Yes	No	No
3	Vitunskaitė et al., 2019	computers & security	2019	Comparative Study	Yes	Yes	No	No	Yes
3	Malatji et al., 2020	computers & security	2020	Mixed Methods	Yes	Yes	No	Yes	No
3	Bongiovanni et al., 2024	information and computer security	2022	Literature review	Yes	Yes	No	No	No
3	Radunović et al., 2025	computers & security	2025	Quantitative	Yes	Yes	No	Yes	No
4	Gerber and von Solms, 2001	computers & security	2001	Conceptual	Yes	Yes	No	No	No
4	Chan, 2011	computer journal	2011	Qualitative	Yes	Yes	Yes	No	No
4	Silva et al., 2014	international journal of information management	2014	Quantitative	Yes	Yes	No	No	No
4	Webb et al., 2014	computers & security	2014	Conceptual	Yes	Yes	Yes	No	No
4	Bamakan and Dehghanimohammadabadi, 2015	international journal of enterprise information systems	2015	Quantitative	Yes	Yes	No	No	No

(continued on next page)

(continued)

Topic	Paper	Journal	Year	Method	I	P	D	Rp	Rc
4	Joshi and Singh, 2017	journal of information security and applications	2017	Quantitative	Yes	Yes	No	No	No
4	McLeod and Dolezel, 2018	decision support systems	2018	Quantitative	Yes	Yes	No	No	No
4	Palma et al., 2025	expert systems with applications	2025	Quantitative	Yes	Yes	No	No	No
5	Rhee et al., 2012	computers & security	2012	Quantitative	Yes	Yes	No	Yes	No
5	Yoon et al., 2012	journal of information systems education	2018	Quantitative	Yes	Yes	No	No	No
5	Safa et al., 2016	computers & security	2016	Quantitative	No	Yes	No	No	No
5	van Schaik et al., 2017	computers in human behavior	2017	Quantitative	Yes	Yes	No	No	No
5	Jansen and van Schaik, 2018	computers in human behavior	2018	Quantitative	Yes	Yes	No	No	No
5	Hina et al., 2019	computers & security	2019	Quantitative	Yes	Yes	No	No	No
6	Awan et al., 2016	computers & security	2016	Quantitative	Yes	No	Yes	No	No
6	Garg et al., 2018	computers & security	2018	Conceptual	Yes	No	No	No	No
6	Stergiopoulos et al., 2020	computers & security	2020	Quantitative	Yes	Yes	No	No	No
6	Luo et al., 2021	security and communication networks	2021	Conceptual	Yes	Yes	No	No	No
6	Asvija et al., 2021	journal of organizational and end user computing	2021	Quantitative	Yes	Yes	No	No	No
6	Chahal et al., 2022	computers & security	2022	Quantitative	Yes	Yes	Yes	Yes	No
6	Wang et al., 2025	expert systems with applications	2025	Quantitative	Yes	No	No	No	No
7	Webb, 2000	computers & security	2000	Conceptual	Yes	Yes	No	No	No
7	Kovacich and Boni, 2000	computers & security	2000	Conceptual	Yes	No	No	No	No
7	Keller et al., 2005	information systems management	2005	Qualitative	Yes	Yes	No	No	No
7	Knapp and Boulton, 2006	information systems management	2006	Literature review	Yes	Yes	No	No	No
7	Baker et al., 2007	communications of the acm	2007	Qualitative	Yes	No	No	No	No
7	Gupta et al., 2011	communications of the association for information systems	2011	Conceptual	Yes	Yes	No	No	Yes
7	Slapnicar et al., 2025	australasian journal of information systems	2025	Mixed Methods	Yes	Yes	Yes	No	No
8	Arora et al., 2006	information systems frontiers	2006	Quantitative	Yes	Yes	No	No	No
8	Ryan and Ryan, 2006	computers & security	2006	Quantitative	Yes	Yes	No	No	No
8	Lee et al., 2011	decision support systems	2011	Conceptual	Yes	Yes	No	No	No
8	Farahmand and Spafford, 2013	information systems frontiers	2013	Quantitative	Yes	Yes	No	No	No
8	Khalili et al., 2018	ieee transactions on information forensics and security	2018	Conceptual	Yes	Yes	No	No	No
8	Wu et al., 2021	expert systems with applications	2021	Quantitative	Yes	Yes	No	No	No
9	Lowry et al., 2015	information systems journal	2015	Quantitative	Yes	Yes	No	No	No
9	Alshare et al., 2018	information and computer security	2018	Quantitative	Yes	Yes	No	Yes	No
9	Kumah et al., 2019	information and computer security	2019	Quantitative	Yes	Yes	No	No	No
9	Tang et al., 2020	journal of enterprise information management	2020	Quantitative	Yes	Yes	No	No	No
9	Abbas et al., 2021	online information review	2021	Quantitative	Yes	Yes	No	No	No
9	Silaule et al., 2022	south african journal of information management	2022	Quantitative	Yes	Yes	No	No	No
9	Pharris and Perez-Mira, 2022	information and computer security	2022	Qualitative	Yes	Yes	No	Yes	No
9	Hu et al., 2023	internet research	2023	Quantitative	Yes	Yes	No	No	No
10	Tryfonas et al., 2007	internet research	2007	Quantitative	Yes	Yes	No	No	No
10	Sharma and Routroy, 2016	journal of enterprise information management	2016	Conceptual	Yes	Yes	No	No	No
10	Alavi et al., 2016	information and computer security	2016	Mixed Methods	Yes	Yes	No	No	No
10	Stewart and Jürjens, 2017	information and computer security	2017	Quantitative	Yes	Yes	No	No	No
10	Tamrin et al., 2017	aslib journal of information management	2017	SLR	Yes	Yes	No	No	No
10	Anand et al., 2018	information and computer security	2018	Case Study	Yes	Yes	No	No	No
10	Jamil et al., 2024	information and computer security	2025	Quantitative	Yes	Yes	No	No	No
11	Tarafdar and Bose, 2019	journal of organizational computing and electronic commerce	2019	Case Study	Yes	Yes	No	No	No
11	Fenz et al., 2011	communications of the association for information systems	2011	Case Study	Yes	Yes	No	No	No
11	Oetzel and Spiekermann, 2014	europaean journal of information systems	2014	Conceptual	Yes	Yes	No	No	No
11	Santini et al., 2019	security and communication networks	2019	Quantitative	Yes	No	No	No	No
11	Varga et al., 2021	computers & security	2021	Mixed Methods	Yes	No	Yes	No	No
11	Meland et al., 2022	journal of information security and applications	2022	Case Study	Yes	No	No	No	No
11	Chiba et al., 2025	computers & security	2025	Quantitative	Yes	Yes	No	No	No
12	Vaughn et al., 2002	journal of systems and software	2002	Qualitative	Yes	Yes	No	Yes	No
12	Knapp et al., 2009	computers & security	2009	Qualitative	Yes	Yes	No	No	No
12	Ransbotham and Mitra, 2009	information systems research	2009	Qualitative	Yes	Yes	Yes		No
12	Baker, 2014	information technology for development	2014	Conceptual	Yes	Yes	No	No	No
12	Anderson et al., 2017	journal of management information systems	2017	Qualitative	Yes	Yes	No	No	No
12	Spears, 2018	journal of information systems education	2018	Instructional guide	Yes	Yes	No	No	No
12	McGregor et al., 2024	journal of computer information systems	2024	Literature review	Yes	Yes	No	Yes	No
12	Pool et al., 2024	international journal of information management	2024	Literature review	Yes	Yes	No	Yes	No
13	Sen and Borle, 2015	journal of management information systems	2015	Quantitative	Yes	Yes	No	No	No
13	Choucri et al., 2014	information technology for development	2014	Quantitative	Yes	Yes	No	Yes	No
13	Tsen et al., 2022	journal of organizational computing and electronic commerce	2022	Quantitative	Yes	Yes	Yes	Yes	Yes
13	Burton-Jones and Wang, 2023	journal of management information systems	2023	Conceptual	Yes	Yes	No	No	No
13	Cremer et al., 2024	computers & security	2024	Mixed Methods	Yes	Yes	No	No	Yes
13	Fernandez de Arroyabe et al., 2024	journal of computer information systems	2024	Quantitative	Yes	Yes	No	No	No
14	Von Solms, 2005	computers & security	2005	Conceptual	Yes	Yes	Yes	No	No
14	Von Solms, 2005	computers & security	2005	Conceptual	Yes	No	No	No	No
14	Von Solms and von Solms, 2006	computers & security	2005	Opinion paper	Yes	Yes	No	No	No
14	Von Solms, 2006	computers & security	2006	Conceptual	No	Yes	No	No	No
14	Von Solms and von Solms, 2006	computers & security	2006	Conceptual	Yes	Yes	Yes	No	No
14	Ramezan, 2025	computers & security	2025	Quantitative	No	No	No	No	No

(continued on next page)

(continued)

Topic	Paper	Journal	Year	Method	I	P	D	Rp	Rc
15	Peisert et al., 2007	ieee transactions on dependable and secure computing	2007	Quantitative	Yes	No	Yes	Yes	No
15	Holm et al., 2015	ieee transactions on dependable and secure computing	2015	Quantitative	Yes	No	No	No	No
15	Harang and Kott, 2017	ieee transactions on information forensics and security	2017	Quantitative	Yes	No	No	No	No
15	Derbyshire et al., 2021	computers & security	2021	Conceptual	Yes	No	No	No	No
15	Xu et al., 2021	computers in human behavior	2021	Quantitative	Yes	No	No	No	No
15	Daubner et al., 2023	journal of information security and applications	2023	Conceptual	Yes	No	Yes	No	No
16	Pham and Hassandoust, 2025	information and computer security	2025	Quantitative	No	Yes	No	No	No
16	Connolly et al., 2019	information Systems Management	2019	Qualitative	Yes	Yes	No	No	No
16	Paliszkievicz, 2019	journal of Computer Information Systems	2019	Quantitative	Yes	Yes	No	No	No
16	Koohang et al., 2020	journal of Computer Information Systems	2020	Quantitative	Yes	Yes	No	No	No
16	Nord et al., 2022	journal of Computer Information Systems	2022	Quantitative	Yes	Yes	No	No	No
17	Bernard, 2007	computers & security	2007	Conceptual	Yes	Yes	No	No	No
17	Demirkan and Goul, 2013	information systems and e-business management	2013	Conceptual	Yes	Yes	No	No	No
17	Alruwaili and Gulliver, 2018	journal of information security and applications	2018	Case Study	Yes	Yes	No	No	No
17	Akinrolabu et al., 2019	computers & security	2019	Conceptual	Yes	No	No	No	No
17	Ali et al., 2020	government information quarterly	2020	Mixed Methods	Yes	Yes	No	No	No
17	Thompson et al., 2020	government information quarterly	2020	Quantitative	Yes	No	No	No	No
18	Wang et al., 2015	mis quarterly	2015	Quantitative	Yes	Yes	Yes	No	No
18	Qamar et al., 2017	computers & security	2017	Quantitative	Yes	No	Yes	Yes	No
18	Biswas et al., 2022	decision support systems	2022	Quantitative	Yes	No	Yes	Yes	No
18	Ebrahimi et al., 2020	journal of management information systems	2020	Quantitative	Yes	No	Yes	No	No
18	Hammouchi et al., 2023	ieee transactions on dependable and secure computing	2023	Quantitative	Yes	No	Yes	No	No
18	McIntosh et al., 2023	computers & security	2023	Quantitative	Yes	Yes	No	Yes	No
18	Ampel et al., 2024	journal of management information systems	2024	Quantitative	Yes	Yes	Yes	Yes	No
19	Sun et al., 2006	journal of management information systems	2006	Quantitative	Yes	Yes	No	No	No
19	Johnson, 2008	journal of management information systems	2008	Quantitative	Yes	No	Yes	No	No
19	Wang et al., 2008	information systems research	2008	Conceptual	Yes	Yes	No	No	No
19	Rees et al., 2011	decision support systems	2011	Quantitative	Yes	Yes	No	No	No
19	Wang et al., 2013	information systems research	2013	Quantitative	Yes	No	No	No	No
19	Shang et al., 2019	security and communication networks	2019	Quantitative	Yes	No	No	No	No
20	Bulgurcu et al., 2010	mis quarterly	2010	Quantitative	Yes	Yes	No	No	No
20	Flores and Ekstedt, 2016	computers & security	2016	Mixed Methods	Yes	Yes	No	No	No
20	Klobas et al., 2019	computers & security	2019	Quantitative	Yes	Yes	No	No	No
20	Reeves et al., 2021	computers & security	2021	Quantitative	Yes	Yes	No	No	No
20	Yang et al., 2022	internet research	2022	Quantitative	Yes	Yes	No	No	No
20	Bansal and Axelton, 2024	journal of computer information systems	2024	Quantitative	Yes	No	No	No	No
20	Davis et al., 2024	computers & security	2024	Quantitative	Yes	Yes	No	No	No
21	Sharma and Mukhopadhyay, 2021	journal of organizational computing and electronic commerce	2021	Quantitative	Yes	No	Yes	Yes	No
21	Samtani et al., 2022	mis quarterly	2022	Quantitative	Yes	No	Yes	No	No
21	Sharma and Mukhopadhyay, 2023	information systems frontiers	2023	Quantitative	Yes	No	Yes	Yes	No
21	Callahan et al., 2023	ieee transactions on dependable and secure computing	2023	Quantitative	Yes	Yes	Yes	No	No
21	Cao et al., 2024	ieee transactions on dependable and secure computing	2024	Quantitative	Yes	Yes	Yes	No	No
21	Yousaf et al., 2025	computers & security	2025	Quantitative	Yes	Yes	No	No	No

APPENDIX B. Clustering validation and model selection

This appendix reports the validation and model comparison procedures used to justify the clustering solution. In the main method, document embeddings were clustered to identify topics, after which representative documents were selected from the topic-document probability matrix for qualitative coding (Appendix A). Specifically, the clustering solution yielded 22 topics and 159 representative documents which were subsequently used for thematic analysis.

B.1. Validation logic

We evaluated the clustering solution using a set of internal clustering validation metrics. Because the clustering approach is HDBSCAN, the Density-Based Clustering Validation (DBCv) score (Moulavi et al., 2014) is particularly relevant, as it is designed for density-based clustering. We complement DBCv with the Silhouette coefficient, Davies-Bouldin index, and Calinski-Harabasz index to provide a broader assessment of cluster cohesion and separation (Raha et al., 2025). Higher values of DBCv, Silhouette, and Calinski-Harabasz indicate stronger clustering structure, whereas lower values of the Davies-Bouldin index indicate better separation among clusters. We first examined the behavior of the Cyber-Risk-Llama-3-8B embeddings across a range of min_cluster_size values. This parameter sweep was used to assess the tradeoff between cluster granularity and internal validation quality. Fig. B1 visualizes the behavior of the key metrics across the tested settings, and Table B1 reports the corresponding values.

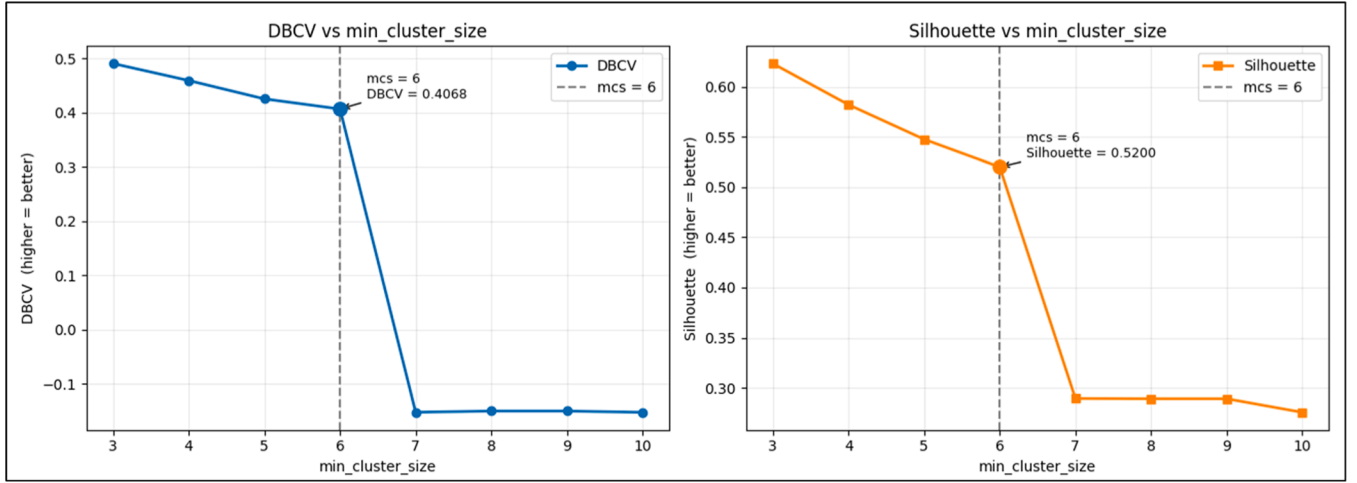


Fig. B1. DBCV and Silhouette across min_cluster_size values for Cyber-Risk-Llama-3-8B.

Table B1

HDBSCAN parameter sweep and internal validation results for Cyber-Risk-Llama-3-8B.

min_cluster_size (mcs)	num_clusters	DBCV	Silhouette_score	Davies_Bouldin	Calinski_Harabasz
3	61	0.490713	0.623097	0.43459	1930.095
4	42	0.459323	0.582069	0.46357	838.8453
5	34	0.425444	0.547602	0.49358	734.2418
6	22	0.406766	0.520014	0.51717	622.1693
7	2	-0.152088	0.289506	0.63985	61.98591
8	2	-0.149925	0.289252	0.64082	61.80965
9	2	-0.149925	0.289252	0.64082	61.80965
10	2	-0.152254	0.275737	0.64219	53.59778

Across lower values of min_cluster_size, the clustering solution produced a larger number of clusters and stronger internal validation scores. As min_cluster_size increased, the number of clusters declined steadily from 61 to 22 while the validation metrics remained positive. At min_cluster_size = 6, the model produced 22 clusters with positive DBCV, Silhouette, Davies-Bouldin, and Calinski-Harabasz values. Beyond this point, the solution collapsed to two clusters and the DBCV became negative, indicating a degenerate clustering structure. On this basis, min_cluster_size = 6 was selected as the final setting because it represented the last non-degenerate solution while also yielding an interpretable 22-cluster structure.

B.2. Cross-model comparison

After selecting min_cluster_size = 6, we compared the clustering solution against alternative embedding models. The comparison included seven models with distinct roles: Cyber-Risk-Llama-3-8B as the primary cybersecurity-specific large language model; CySecBERT (Bayer et al., 2024), SecBERT (Huang and Wang, 2024), and SecureBERT⁶ as cybersecurity-focused baselines; BERT-base-uncased as a general-purpose language baseline; all-MiniLM-L6-v2⁷ as a widely used sentence-embedding baseline optimized for semantic similarity; and FinBERT (Huang et al., 2023) as an off-domain benchmark. This comparison allowed us to evaluate whether cybersecurity-oriented embeddings produced stronger clustering performance than general-purpose or non-aligned alternatives.

Table B2 reports the clustering results for each model at the same parameter setting.

Table B2

Cross-model comparison of clustering performance.

Model	min_cluster_size	num_clusters	DBCV	Silhouette_score	Davies_Bouldin	Calinski_Harabasz
Cyber-Risk-Llama-3-8B	6	22	0.406766	0.520014	0.517168	622.16926
CySecBERT	6	15	0.118396	0.427106	0.49674	245.731125
SecureBERT	6	18	0.39048	0.47046	0.511339	976.290862
SecBERT	6	23	0.353018	0.477887	0.493604	984.468326
all-MiniLM-L6-v2	6	5	0.283185	0.317077	0.527449	122.36289
FinBERT	6	9	-0.19543	0.12542	0.597388	62.203572
BERT-base	6	24	0.405958	0.517518	0.522768	551.465918

At min_cluster_size = 6, Cyber-Risk-Llama-3-8B achieved the strongest DBCV and Silhouette values among the compared models. BERT-base

⁶ <https://github.com/ehsanaghaei/SecureBERT>

⁷ <https://huggingface.co/sentence-transformers/all-MiniLM-L6-v2>

produced a closely comparable result. SecureBERT and SecBERT were also competitive but did not match density-based validation and silhouette score.

B.3. Interpreting the clustering solution

The 22-cluster configuration should be interpreted as a balance between interpretability and statistical support rather than as the strongest-scoring solution across all tested parameter values. Lower min_cluster_size values generated more clusters and stronger metric values, but they also produced substantially more fragmented topic structures. The 22-cluster configuration was selected because it preserved acceptable internal validation while producing a more interpretable topic structure for the subsequent qualitative stage. This is consistent with the broader mixed-methods design of the study, in which the computational clustering stage serves as the foundation for the qualitative interpretation of representative documents and the development of aggregate dimensions.

Data availability

No data was used for the research described in the article.

References

- Abbas, H.S.M., Qaisar, Z.H., Xu, X., Sun, C., 2022. Nexus of E-government, cybersecurity and corruption on public service (PSS) sustainability in Asian economies using fixed-effect and random forest algorithm. *Online Inf. Rev.* 46 (4), 754–770. <https://doi.org/10.1108/OIR-02-2021-0069>.
- Abraham, C., Chatterjee, D., Sims, R.R., 2019. Muddling through cybersecurity: insights from the U.S. healthcare industry. *Bus. Horiz.* 62 (4), 539–548. <https://doi.org/10.1016/j.bushor.2019.03.010>.
- Ahmad, A., Desouza, K.C., Maynard, S.B., Naseer, H., Baskerville, R.L., 2020. How integration of cyber security management and incident response enables organizational learning. *J. Assoc. Inf. Sci. Technol.* 71 (8), 939–953. <https://doi.org/10.1002/asi.24311>.
- Akinrolabu, O., Nurse, J.R.C., Martin, A., New, S., 2019. Cyber risk assessment in cloud provider environments: current models and future needs. *Comput. Secur.* 87, 101600. <https://doi.org/10.1016/j.cose.2019.101600>.
- Alahmari, A., Duncan, B., 2020. Cybersecurity risk management in small and medium-sized enterprises: a systematic review of recent evidence. In: 2020 International Conference on Cyber Situational Awareness, Data Analytics and Assessment (CyberSA), pp. 1–5. <https://doi.org/10.1109/CyberSA49311.2020.9139638>.
- Alavi, R., Islam, S., Mouratidis, H., 2016. An information security risk-driven investment model for analysing human factors. *Inf. Comput. Secur.* 24 (2), 205–227. <https://doi.org/10.1108/ICS-01-2016-0006>.
- Alcántara, M., Melgar, A., 2016. Risk management in information security: a systematic review. *J. Adv. Inf. Technol.* 7 (1), 1–7. <https://doi.org/10.12720/jait.7.1.1-7>.
- Ali, O., Shrestha, A., Chatfield, A., Murray, P., 2020. Assessing information security risks in the cloud: a case study of Australian local government authorities. *Gov. Inf. Q.* 37 (1), 101419. <https://doi.org/10.1016/j.giq.2019.101419>.
- Alruwaili, F.F., Gulliver, T.A., 2018. Secure migration to compliant cloud services: a case study. *J. Inf. Secur. Appl.* 38, 50–64. <https://doi.org/10.1016/j.jisa.2017.11.004>.
- Alshare, K.A., Lane, P.L., Lane, M.R., 2018. Information security policy compliance: a higher education case study. *Inf. Comput. Secur.* 26 (1), 91–108. <https://doi.org/10.1108/ICS-09-2016-0073>.
- Ampel, B.M., Samtani, S., Zhu, H., Chen, H., Nunamaker Jr., J.F., 2024. Improving threat mitigation through a cybersecurity risk management framework: a computational design science approach. *J. Manag. Inf. Syst.* 41 (1), 236–265. <https://doi.org/10.1080/07421222.2023.2301178>.
- Amraoui, S., Elmaallam, M., Bensaid, H., Kriouile, A., 2019. Information systems risk management: literature review. *Comput. Inf. Sci.* 12 (3), 1. <https://doi.org/10.5539/cis.v12n3p1>.
- Anand, R., Medhavi, S., Soni, V., Malhotra, C., Banwet, D.K., 2018. Transforming information security governance in India (A SAP-LAP based case study of security, IT policy and e-governance). *Inf. Comput. Secur.* 26 (1), 58–90. <https://doi.org/10.1108/ICS-12-2016-0090>.
- Anderson, E.E., Choobineh, J., 2008. Enterprise information security strategies. *Comput. Secur.* 27 (1), 22–29. <https://doi.org/10.1016/j.cose.2008.03.002>.
- Anderson, R., Barton, C., Böhme, R., Clayton, R., van Eeten, M.J.G., Levi, M., Moore, T., Savage, S., 2013. Measuring the cost of cybercrime. In: Böhme, R. (Ed.), *The Economics of Information Security and Privacy*. Springer, pp. 265–300. https://doi.org/10.1007/978-3-642-39498-0_12.
- Anderson, C., Baskerville, R.L., Kaul, M., 2017. Information security control theory: achieving a sustainable reconciliation between sharing and protecting the privacy of Information. *J. Manag. Inf. Syst.* 34 (4), 1082–1112. <https://doi.org/10.1080/07421222.2017.1394063>.
- Argyris, Ch., Schön, D.A., 1997. Organizational Learning: a theory of action perspective. *Rev. Invest. Sociol.* 77/78, 345. <https://doi.org/10.2307/40183951>.
- Arora, A., Nandkumar, A., Telang, R., 2007. Does information security attack frequency increase with vulnerability disclosure? An empirical analysis. *Inf. Syst. Front.* 8 (5), 350–362. <https://doi.org/10.1007/s10796-006-9012-5>.
- Asvija, B., Eswari, R., Bijoy, M.B., 2021. Security threat modelling with bayesian networks and sensitivity analysis for IAAS virtualization stack. *J. Organ. End User Comput. (JOEUC)* 33 (4), 44–69.
- Awan, M.S.K., Burnap, P., Rana, O., 2016. Identifying cyber risk hotspots: A framework for measuring temporal variance in computer network risk. *Comput. Secur.* 57, 31–46. <https://doi.org/10.1145/1290958.1290969>.
- Baker, W.H., Rees, L.P., Tippet, P.S., 2007. Necessary measures: metric-driven information security risk assessment and decision making. *Commun. ACM* 50 (10), 101–106. <https://doi.org/10.1145/1290958.1290969>.
- Baker, E.W., 2014. A model for the impact of cybersecurity infrastructure on economic development in emerging economies: evaluating the contrasting cases of India and Pakistan. *Inf. Technol. Dev.* 20 (2), 122–139. <https://doi.org/10.1080/02681102.2013.832131>.
- Bamakan, S.M.H., Dehghanimohammadabadi, M., 2015. A weighted Monte Carlo simulation approach to risk assessment of information Security management system. *Int. J. Enterp. Inf. Syst. (IJEIS)* 11 (4), 63–78. <https://doi.org/10.4018/IJEIS.2015100103>.
- Bansal, G., Axelton, Z., 2024. Impact of cybersecurity disclosures on stakeholder intentions. *J. Comput. Inf. Syst.* 64 (1), 78–91. <https://doi.org/10.1080/08874417.2023.2180785>.
- Baskerville, R.L., Kim, J., Stucke, C., 2022. The cybersecurity risk estimation engine: a tool for possibility based risk analysis. *Comput. Secur.* 120, 102752. <https://doi.org/10.1016/j.cose.2022.102752>.
- Baskerville, R., 1991. Risk analysis as a source of professional knowledge. *Comput. Secur.* 10 (8), 749–764. [https://doi.org/10.1016/0167-4048\(91\)90094-T](https://doi.org/10.1016/0167-4048(91)90094-T).
- Baskerville, R.L., 2008. Strategic information security risk management. *Information Security*. Routledge, pp. 112–122.
- Bayer, M., Kuehn, P., Shanehsaz, R., Reuter, C., 2024. Cysecbert: a domain-adapted language model for the cybersecurity domain. *ACM Trans. Priv. Secur.* 27 (2), 1–20. <https://doi.org/10.1145/365259>.
- Bello, A.G., Murray, D., Armarego, J., 2017. A systematic approach to investigating how information security and privacy can be achieved in BYOD environments. *Inf. Comput. Secur.* 25 (4), 475–492. <https://doi.org/10.1108/ICS-03-2016-0025>.
- Bergström, E., Karlsson, F., Ahlfeldt, R.-M., 2021. Developing an information classification method. *Inf. Comput. Secur.* 29 (2), 209–239. <https://doi.org/10.1108/ICS-07-2020-0110>.
- Bernard, R., 2007. Information Lifecycle Security Risk Assessment: a tool for closing security gaps. *Comput. Secur.* 26 (1), 26–30. <https://doi.org/10.1016/j.cose.2006.12.005>.
- Bhana, A., Ophoff, J., 2023. Risk homeostasis and security fatigue: a case study of data specialists. *Inf. Comput. Secur.* 31 (3), 267–280. <https://doi.org/10.1108/ICS-11-2022-0172>.
- Bhatti, B.M., Mubarak, S., Nagalingam, S., 2021. Information security risk management in IT outsourcing – A quarter-century systematic literature review. *J. Glob. Inf. Technol. Manag.* 24 (4), 259–298. <https://doi.org/10.1080/1097198X.2021.1993725>.
- Biswas, B., Mukhopadhyay, A., Bhattacharjee, S., Kumar, A., Delen, D., 2022. A text-mining based cyber-risk assessment and mitigation framework for critical analysis of online hacker forums. *Decis. Support Syst.* 152, 113651. <https://doi.org/10.1016/j.dss.2021.113651>.
- Biswas, B., Mukhopadhyay, A., Kumar, A., Delen, D., 2024. A hybrid framework using explainable AI (XAI) in cyber-risk management for defence and recovery against phishing attacks. *Decis. Support Syst.* 177, 114102. <https://doi.org/10.1016/j.dss.2023.114102>.
- Bitsight, 2023. 7 Cybersecurity KPIs for Your Board of Directors. Bitsight. Retrieved December 9, 2025, from. <https://www.bitsight.com/blog/7-cyber-security-dashboards-kpis-your-board-directors>.
- Bodin, L.D., Gordon, L.A., Loeb, M.P., Wang, A., 2018. Cybersecurity insurance and risk-sharing. *J. Account. Public Policy* 37 (6), 527–544. <https://doi.org/10.1016/j.jaccpubpol.2018.10.004>.
- Bongiovanni, I., Herold, D.M., Wilde, S.J., 2024. Protecting the play: an integrative review of cybersecurity in and for sports events. *Comput. Secur.* 146, 104064. <https://doi.org/10.1016/j.cose.2024.104064>.
- Bopche, G.S., Mehtre, B.M., 2017. Graph similarity metrics for assessing temporal changes in attack surface of dynamic networks. *Comput. Secur.* 64, 16–43. <https://doi.org/10.1016/j.cose.2016.09.010>.
- Borum, R., Felker, J., Kern, S., Dennesen, K., Feyes, T., 2015. Strategic cyber intelligence. *Inf. Comput. Secur.* 23 (3), 317–332. <https://doi.org/10.1108/ICS-09-2014-0064>.
- Bulgurcu, B., Cavusoglu, H., Benbasat, I., 2010. Information security policy compliance: an empirical study of rationality-based beliefs and information security awareness. *MIS Q.* 34, 523–548.

- Burton-Jones, A., Wang, G., 2023. Editor's comments: what makes a journal significant? From the tyranny of metrics to true impact. *MIS Q.* 47 (2), i–xiv. <https://doi.org/10.25300/MISQ/2023/472E1>.
- Butler, M., Butler, R., 2015. Investigating the possibility to use differentiated authentication based on risk profiling to secure online banking. *Inf. Comput. Secur.* 23 (4), 421–434. <https://doi.org/10.1108/ICS-11-2014-0074>.
- Callahan, D., Curry, T., Davidson, H., Zitoun, H., Fuller, B., Michel, L., 2023. FASHION: functional and attack graph secured Hybrid optimization of virtualized networks. *IEEE Trans. Depend. Secure Comput.* 20 (4), 3093–3109. <https://doi.org/10.1109/TDSC.2022.3198843>.
- Cao, Q., Cheng, X., Liao, S., 2023. A comparison study of topic modeling based literature analysis by using full texts and abstracts of scientific articles: a case of COVID-19 research. *Libr. Hi Tech* 41 (2), 543–569. <https://doi.org/10.1108/LHT-03-2022-0144>.
- Cao, G., Wang, Z., Feng, Y., Dong, X., Zhang, Z., Qin, Z., Ren, K., 2024. Task-free fairness-aware bias mitigation for black-box deployed models. *IEEE Trans. Depend. Secure Comput.* 21 (4), 3390–3405. <https://doi.org/10.1109/TDSC.2023.3328663>.
- Chahal, N.S., Bali, P., Khosla, P.K., 2022. A proactive approach to assess web application security through the integration of security tools in a Security orchestration platform. *Comput. Secur.* 122, 102886. <https://doi.org/10.1016/j.cose.2022.102886>.
- Chan, C.-L., 2011. Information security risk modeling using Bayesian index. *Comput. J.* 54 (4), 628–638. <https://doi.org/10.1093/comjnl/bxq059>.
- Chen, P., Kataria, G., Krishnan, R., 2011. Correlated failures, diversification, and information Security risk management. *MIS Q.* 35 (2), 397–3A3. <https://doi.org/10.2307/23044049>.
- Chen, Y.A.N., Ramamurthy, K., Wen, K.W., 2015. Impacts of comprehensive information security programs on information security culture. *J. Comput. Inf. Syst.* 55 (3), 11–19. <https://doi.org/10.1080/08874417.2015.11645767>.
- Chen, H.Y., Das, A., Ivanov, D., 2019. Building resilience and managing post-disruption supply chain recovery: lessons from the information and communication technology industry. *Int. J. Inf. Manag.* 49, 330–342. <https://doi.org/10.1016/j.ijinfomgt.2019.06.002>.
- Cheng, X., Hsu, C., Wang, T.D., 2022. Talk too much? The impact of cybersecurity disclosures on investment decisions. *Commun. Assoc. Inf. Syst.* 50 (1), 481–485. <https://doi.org/10.17705/1CAIS.05022>.
- Chiba, D., Nakano, H., Koide, T., 2025. DomainDynamics: advancing lifecycle-based risk assessment of domain names. *Comput. Secur.* 153, 104366. <https://doi.org/10.1016/j.cose.2025.104366>.
- Choo, K.-K.R., Gai, K., Chiaraviglio, L., Yang, Q., 2021. A multidisciplinary approach to Internet of Things (IoT) cybersecurity and risk management. *Comput. Secur.* 102, 102136. <https://doi.org/10.1016/j.cose.2020.102136>.
- Choucri, N., Madnick, S., Ferwerda, J., 2014. Institutions for Cyber Security: international responses and global imperatives. *Inf. Technol. Dev.* 20 (2), 96–121. <https://doi.org/10.1080/02681102.2013.836699>.
- Cichonski, P., Millar, T., Grance, T., Scarfone, K., 2012. *Computer Security Incident Handling Guide: Recommendations of the National Institute of Standards and Technology* (No. NIST SP 800-61r2; p. NIST SP 800-61r2). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-61r2>.
- COBIT 5. ISACA. Retrieved April 3, 2025, from <https://www.isaca.org/resources/cobit/cobit-5>.
- Connolly, L.Y., Lang, M., Wall, D.S., 2019. Information security behavior: A cross-cultural comparison of Irish and US employees. *Inform. Syst. Manag.* 36 (4), 306–322.
- Cram, W.A., D'Arcy, J., Benlian, A., 2024. Time will tell: the case for an idiographic approach to behavioral cybersecurity research. *MIS Q.* 48 (1), 95–136. <https://doi.org/10.25300/MISQ/2023/17707>.
- Cremer, F., Sheehan, B., Mullins, M., Fortmann, M., Ryan, B.J., Materne, S., 2024. On the insurability of cyber warfare: an investigation into the German cyber insurance market. *Comput. Secur.* 142, 103886. <https://doi.org/10.1016/j.cose.2024.103886>.
- Crossler, R.E., Johnston, A.C., Lowry, P.B., Hu, Q., Warkentin, M., Baskerville, R., 2013. Future directions for behavioral information security research. *Comput. Secur.* 32, 90–101.
- Cucus, A., Sari, W.P., Aminuddin, A., Saputra, D.I.S., Hammood, W.A., Aziza, R.F.A., 2023. Systematic review of IT risk management using a scientometric approach. In: 2023 6th International Conference on Information and Communications Technology (ICOICT), pp. 126–131. <https://doi.org/10.1109/ICOICT59844.2023.10455938>.
- D'Arcy, J., Basoglu, A., 2022. The influences of public and institutional pressure on firms' Cybersecurity disclosures. *J. Assoc. Inf. Syst.* 23 (3), 779–805. <https://doi.org/10.17705/1JAIS.00740>.
- D'Arcy, J., Hovav, A., Galletta, D., 2009. User awareness of security countermeasures and its impact on information systems misuse: a deterrence approach. *Inf. Syst. Res.* 20 (1), 79–98. <https://doi.org/10.1287/isre.1070.0160>.
- Da Veiga, A., Eloff, J.H.P., 2010. A framework and assessment instrument for information security culture. *Comput. Secur.* 29 (2), 196–207. <https://doi.org/10.1016/j.cose.2009.09.002>.
- Da Veiga, A., Martins, N., 2015. Improving the information security culture through monitoring and implementation actions illustrated through a case study. *Comput. Secur.* 49, 162–176. <https://doi.org/10.1016/j.cose.2014.12.006>.
- Daft, R.L., Lengel, R.H., 1986. Organizational information requirements, Media richness and structural design. *Manag. Sci.* 32 (5), 554–571. <https://doi.org/10.1287/mnsc.32.5.554>.
- Daubner, L., Macak, M., Matulevičius, R., Buhnova, B., Maksović, S., Pitner, T., 2023. Addressing insider attacks via forensic-ready risk management. *J. Inf. Secur. Appl.* 73, 103433. <https://doi.org/10.1016/j.jisa.2023.103433>.
- Davis, J.M., Agrawal, D., Austin, R., 2024. Fostering security-related citizenship through the employee-supervisor relationship: an examination of supervisor security embodiment. *Comput. Secur.* 142, 103896. <https://doi.org/10.1016/j.cose.2024.103896>.
- De Smet, D., Mayer, N., 2016. Integration of it governance and security risk management: a systematic literature review. In: 2016 International Conference on Information Society (i-Society), pp. 143–148. <https://doi.org/10.1109/i-Society.2016.7854200>.
- Deane, J., Baker, W., Rees, L., 2023. Cybersecurity in supply chains: quantifying risk. *J. Comput. Inf. Syst.* 63 (3), 507–521. <https://doi.org/10.1080/08874417.2022.2081882>.
- Demirkan, H., Goul, M., 2013. Taking value-networks to the cloud services: security services, semantics and service level agreements. *Inf. Syst. E-Bus. Manag.* 11 (1), 51–91. <https://doi.org/10.1007/s10257-011-0186-0>.
- Derbyshire, R., Green, B., Hutchison, D., 2021. Talking a different language": anticipating adversary attack cost for cyber risk assessment. *Comput. Secur.* 103, 102163. <https://doi.org/10.1016/j.cose.2020.102163>.
- Desalegn, E.G., Guedes, M.J.C., Da Silva Gomes, J.F., Tebeka, S.M., 2024. Disentangling organizational agility from flexibility, adaptability, and versatility: a systematic review. *Fut. Bus. J.* 10 (1), 117. <https://doi.org/10.1186/s43093-024-00405-6>.
- Devi, R.K., Sensuse, D.I., Kautsarina, & Suryono, R.R. (2022). *Information Security Risk Assessment (ISRA): a Systematic Literature Review*. | *Journal of Information Systems Engineering & Business Intelligence* | EBSCOhost. <https://doi.org/10.20473/jisebi.8.2.207-217>.
- Dhillon, G., Backhouse, J., 2001. Current directions in IS security research: towards socio-organizational perspectives. *Inf. Syst. J.* 11 (2), 127–153. <https://doi.org/10.1046/j.1365-2575.2001.00099.x>.
- Diefenbach, T., Lucke, C., Lechner, U., 2019. Towards an integration of information security management, risk management and enterprise architecture management – a literature review. In: 2019 IEEE International Conference on Cloud Computing Technology and Science (CloudCom), pp. 326–333. <https://doi.org/10.1109/CloudCom.2019.00057>.
- Duchek, S., 2020. Organizational resilience: a capability-based conceptualization. *Bus. Res.* 13 (1), 215–246. <https://doi.org/10.1007/s40685-019-0085-7>.
- Ebrahimi, M., Nunamaker Jr., J.F., Chen, H., 2020. Semi-supervised cyber threat identification in dark net markets: a transductive and deep learning approach. *J. Manag. Inf. Syst.* 37 (3), 694–722. <https://doi.org/10.1080/07421222.2020.1790186>.
- Eling, M., McShane, M., Nguyen, T., 2021. Cyber risk management: history and future research directions. *Risk Manag. Insur. Rev.* 24 (1), 93–125. <https://doi.org/10.1111/rmir.12169>.
- Faily, S., 2015. Engaging stakeholders during late stage security design with assumption personas. *Inf. Comput. Secur.* 23 (4), 435–446. <https://doi.org/10.1108/ICS-10-2014-0066>.
- FAIR. *Measuring and managing information risk: a FAIR approach*. Retrieved April 3, 2025, from <https://www.fairinstitute.org/fair-book>.
- Farahmand, F., Spafford, E.H., 2013. Understanding insiders: an analysis of risk-taking behavior. *Inf. Syst. Front.* 15 (1), 5–15. <https://doi.org/10.1007/s10796-010-9265-x>.
- Fenz, S., Ekelhart, A., Neubauer, T., 2011. Information security risk management: in which security solutions is it worth investing? *Commun. Assoc. Inf. Syst.* 28 (1), 22. <https://doi.org/10.17705/1CAIS.02822>.
- Fenz, S., Heurix, J., Neubauer, T., Pechstein, F., 2014. Current challenges in information security risk management. *Inf. Manag. Comput. Secur.* 22 (5), 410–430. <https://doi.org/10.1108/IMCS-07-2013-0053>.
- Fernandez de Arroyabe, J.C., Arroyabe, M.F., Fernandez, I., Arranz, C.F.A., 2024. Cybersecurity resilience in SMEs. A machine learning approach. *J. Comput. Inf. Syst.* 64 (6), 711–727. <https://doi.org/10.1080/08874417.2023.2248925>.
- Fink, A., 2019. *Conducting Research Literature Reviews: From the Internet to Paper*. SAGE Publications.
- Flowerday, S.V., Tuyikeze, T., 2016. Information security policy development and implementation: the what, how and who. *Comput. Secur.* 61, 169–183. <https://doi.org/10.1016/j.cose.2016.06.002>.
- Fortin, A., Héroux, S., 2023. Limited usefulness of firm-provided cybersecurity information in institutional investors' investment analysis. *Inf. Comput. Secur.* 31 (1), 108–123. <https://doi.org/10.1108/ICS-07-2022-0122>.
- Franco, M.F., Künzler, F., von der Assen, J., Feng, C., Stiller, B., 2024. RCVaR: an economic approach to estimate cyberattacks costs using data from industry reports. *Comput. Secur.* 139, 103737. <https://doi.org/10.1016/j.cose.2024.103737>.
- Gale, M., Bongiovanni, I., Slapnicar, S., 2022. Governing cybersecurity from the boardroom: challenges, drivers, and ways ahead. *Comput. Secur.* 121, 102840. <https://doi.org/10.1016/j.cose.2022.102840>.
- Garg, U., Sikka, G., Awasthi, L.K., 2018. Empirical analysis of attack graphs for mitigating critical paths and vulnerabilities. *Comput. Secur.* 77, 349–359. <https://doi.org/10.1016/j.cose.2018.04.006>.
- Gerber, M., von Solms, R., 2001. From risk analysis to security requirements. *Comput. Secur.* 20 (7), 577–584. [https://doi.org/10.1016/S0167-4048\(01\)00706-4](https://doi.org/10.1016/S0167-4048(01)00706-4).
- Gerber, M., von Solms, R., 2005. Management of risk in the information age. *Comput. Secur.* 24 (1), 16–30. <https://doi.org/10.1016/j.cose.2004.11.002>.
- Gioia, D.A., Corley, K.G., Hamilton, A.L., 2013. Seeking qualitative rigor in inductive research: notes on the Gioia methodology. *Organ. Res. Methods* 16 (1), 15–31. <https://doi.org/10.1177/1094428112452151>.
- Goodman, S., Straub, D.W., Baskerville, R., Baskerville, R., 2016. *Information Security: Policy, Processes, and Practices*. Routledge. <https://doi.org/10.4324/9781315288697>.

- Gruetzemacher, R., Paradise, D., 2022. Deep transfer learning & beyond: transformer language models in information systems research. *ACM Comput. Surv.* 54 (10s), 1–35. <https://doi.org/10.1145/3505245>.
- Gunes, B., Kayisoglu, G., Bolat, P., 2021. Cyber security risk assessment for seaports: a case study of a container port. *Comput. Secur.* 103, 102196. <https://doi.org/10.1016/j.cose.2021.102196>.
- Gupta, M., Chaturvedi, A., Mehta, S., 2011. Economic analysis of tradeoffs between security and disaster recovery. *Commun. Assoc. Inf. Syst.* 28 (1), 1. <https://doi.org/10.17705/1CAIS.02801>.
- Gyllensten, K., Pousette, A., Törner, M., 2022. Value conflicts and information security – a mixed-methods study in high-risk industry. *Inf. Comput. Secur.* 30 (3), 346–363. <https://doi.org/10.1108/ICS-09-2021-0139>.
- Hammouchi, H., Nejari, N., Mezzour, G., Ghogho, M., Benbrahim, H., 2023. STRisk: a socio-technical approach to assess hacking breaches risk. *IEEE Trans. Depend. Secure Comput.* 20 (2), 1074–1087. <https://doi.org/10.1109/TDSC.2022.3149208>.
- Haqaf, M., Koyuncu, M., 2018. Understanding key skills for information security managers. *Int. J. Inf. Manag.* 43, 165–172. <https://doi.org/10.1016/j.ijinfomgt.2018.07.013>.
- Harang, R., Kott, A., 2017. Burstiness of intrusion detection process: empirical evidence and a modeling approach. *IEEE Trans. Inf. Forensics Secur.* 12 (10), 2348–2359. <https://doi.org/10.1109/TIFS.2017.2705629>.
- He, Y., Johnson, C., 2017. Challenges of information security incident learning: an industrial case study in a Chinese healthcare organization. *Inform. Health Soc. Care* 42 (4), 393–408. <https://doi.org/10.1080/17538157.2016.1255629>.
- Herath, T., Rao, H.R., 2009. Protection motivation and deterrence: a framework for security policy compliance in organisations. *Eur. J. Inf. Syst.* 18 (2), 106–125. <https://doi.org/10.1057/ejis.2009.6>.
- Hina, S., Panneer Selvam, D.D.D., Lowry, P.B., 2019. Institutional governance and protection motivation: theoretical insights into shaping employees' security compliance behavior in higher education institutions in the developing world. *Comput. Secur.* 87, 101594. <https://doi.org/10.1016/j.cose.2019.101594>.
- Holm, H., Shahzad, K., Buschle, M., Ekstedt, M., 2015. P² CySeMoL: predictive, probabilistic cyber security modeling language. *IEEE Trans. Depend. Secure Comput.* 12 (6), 626–639. <https://doi.org/10.1109/TDSC.2014.2382574>.
- Hu, S., Hsu, C., Zhou, Z., 2022. Security education, training, and awareness programs: literature review. *J. Comput. Inf. Syst.* 62 (4), 752–764. <https://doi.org/10.1080/08874417.2021.1913671>.
- Hu, S., Hsu, C., Zhou, Z., 2024. Understanding employees' perceptions of SETA events: the role of pedagogical and communication approaches. *Internet Res.* 34 (2), 294–319. <https://doi.org/10.1108/INTR-06-2022-0455>.
- Huang, H., Wang, Y., 2024. SecBERT: privacy-preserving pre-training based neural network inference system. *Neural Netw.* 172, 106135. <https://doi.org/10.1016/j.neunet.2024.106135>.
- Huang, A.H., Wang, H., Yang, Y., 2023. FinBERT: a large language model for extracting information from financial text. *Contemp. Account. Res.* 40 (2), 806–841. <https://doi.org/10.1111/1911-3846.12832>.
- Ifinedo, P., 2012. Understanding information systems security policy compliance: an integration of the theory of planned behavior and the protection motivation theory. *Comput. Secur.* 31, 83–95. <https://doi.org/10.1016/j.cose.2011.10.007>.
- ISACA, 2010. Past Journals 2010 developing an information Security and Risk Management strategy. Retrieved April 3, 2025, from <https://www.isaca.org/resoures/isaca-journal/past-issues/2010/developing-an-information-security-and-risk-management-strategy>.
- ISACA, 2021. Press Releases 2021 Tactics for Effectively Communicating Cybersecurity Risk to BOD Outlined in NewISACAPaper. ISACA. Retrieved December 9, 2025, from <https://www.isaca.org/about-us/newsroom/press-releases/2021/tactics-for-effectively-communicating-cybersecurity-risk-to-bod-outlined-in-new-isaca-paper>.
- ISO/IEC 27005. ISO. Retrieved April 3, 2025, from <https://www.iso.org/standard/80585.html>.
- Jamil, H., Zia, T., Nayeem, T., Whitty, M.T., D'Alessandro, S., 2025. Human-centric cyber security: applying protection motivation theory to analyse micro business owners' security behaviours. *Inf. Comput. Secur.* 33 (1), 49–76. <https://doi.org/10.1108/ICS-10-2023-0176>.
- Janakiraman, R., Lim, J.H., Rishika, R., 2018. The effect of a data breach announcement on customer behavior: evidence from a multichannel retailer. *J. Mark.* 82 (2), 85–105. <https://doi.org/10.1509/jm.16.0124>.
- Jansen, J., van Schaik, P., 2018. Testing a model of precautionary online behaviour: the case of online banking. *Comput. Hum. Behav.* 87, 371–383. <https://doi.org/10.1016/j.chb.2018.05.010>.
- Johnson, M.E., 2008. Information risk of inadvertent disclosure: an analysis of file-sharing risk in the financial supply chain. *J. Manag. Inf. Syst.* 25 (2), 97–124. <https://doi.org/10.2753/MIS0742-1222250205>.
- Joshi, C., Singh, U.K., 2017. Information security risks management framework – A step towards mitigating security risks in university network. *J. Inf. Secur. Appl.* 35, 128–137. <https://doi.org/10.1016/j.jisa.2017.06.006>.
- Keller, S., Powell, A., Horstmann, B., Predmore, C., Crawford, M., 2005. Information security threats and practices in small businesses. *Inf. Syst. Manag.* 22 (2), 7–19. <https://doi.org/10.1201/1078/45099.22.2.20050301/87273.2>.
- Khalili, M.M., Naghizadeh, P., Liu, M., 2018. Designing Cyber insurance policies: the role of pre-screening and security interdependence. *IEEE Trans. Inf. Forens. Secur.* 13 (9), 2226–2239. <https://doi.org/10.1109/TIFS.2018.2812205>.
- Kitchenham, B., 2004. Procedures for performing systematic reviews. *Keele UK Keele Univ.* 33 (2004), 1–26.
- Klobas, J.E., McGill, T., Wang, X., 2019. How perceived security risk affects intention to use smart home devices: a reasoned action explanation. *Comput. Secur.* 87, 101571. <https://doi.org/10.1016/j.cose.2019.101571>.
- Knapp, K.J., Boulton, W.R., 2006. Cyber-warfare threatens corporations: expansion into commercial environments. *Inf. Syst. Manag.* 23 (2), 76–87. <https://www.tandfonline.com/doi/abs/10.1201/1078.10580530/45925.23.2.20060301/92675.8>.
- Knapp, K.J., Franklin Morris, R., Marshall, T.E., Byrd, T.A., 2009. Information security policy: an organizational-level process model. *Comput. Secur.* 28 (7), 493–508. <https://doi.org/10.1016/j.cose.2009.07.001>.
- Koohang, A., Nowak, A., Paliszkievicz, J., Nord, J.H., 2020. Information security policy compliance: leadership, trust, role values, and awareness. *J. Comput. Inf. Syst.* 60 (1), 1–8. <https://doi.org/10.1080/08874417.2019.1668738>.
- Kovacic, G.L., Boni, W.C., 2000. Internet targets. *Comput. Secur.* 19 (2), 133–140. [https://doi.org/10.1016/S0167-4048\(00\)87823-2](https://doi.org/10.1016/S0167-4048(00)87823-2).
- Kruger, H.A., Kearney, W.D., 2006. A prototype for assessing information security awareness. *Comput. Secur.* 25 (4), 289–296. <https://doi.org/10.1016/j.cose.2006.02.008>.
- Kumah, P., Yaokumah, W., Okai, E.S.A., 2019. A conceptual model and empirical assessment of HR security risk management. *Inf. Comput. Secur.* 27 (3), 411–433. <https://doi.org/10.1108/ICS-05-2018-0057>.
- Kurt, Y.B., Uflaz, E., Akyuz, E., Kurt, R.E., Turan, O., 2025. Analysis of human reliability in detecting GPS spoofing on ECDIS in congested waterways under evidential reasoning and HEART approach. *Comput. Secur.* 151, 104316. <https://doi.org/10.1016/j.cose.2025.104316>.
- Uruña López, A., Mateo, F., Navío-Marco, J., Martínez-Martínez, J.M., Gómez-Sánchez, J., Vila-Francés, J., José Serrano-López, A., 2019. Analysis of computer user behavior, security incidents and fraud using self-organizing maps. *Comput. Secur.* 83, 38–51. <https://doi.org/10.1016/j.cose.2019.01.009>.
- Lee, M.-T., Su, Z.-Y., Hou, Y.-H., Liao, H.-C., Lian, J.-D., 2011. A decision support system for diagnosis related groups coding. *Expert Syst. Appl.* 38 (4), 3626–3631. <https://doi.org/10.1016/j.eswa.2010.09.016>.
- Leidner, D., 2018. Review and theory symbiosis: an introspective retrospective. *J. Assoc. Inf. Syst.* 19 (6), 552–567. <https://aisel.aisnet.org/jais/vol19/iss6/1>.
- Lo, C.-C., Chen, W.-J., 2012. A hybrid information security risk assessment procedure considering interdependences between controls. *Expert Syst. Appl.* 39 (1), 247–257. <https://doi.org/10.1016/j.eswa.2011.07.015>.
- Lowry, P.B., Moody, G.D., 2015. Proposing the control-reactance compliance model (CRCM) to explain opposing motivations to comply with organisational information security policies. *Inf. Syst. J.* 25 (5), 433–463. <https://doi.org/10.1111/isj.12043>.
- Lowry, P., Gaskin, J., Moody, G., 2015. Proposing the multimotive information systems continuance model (MISC) to better explain end-user system evaluations and continuance intentions. *J. Assoc. Inf. Syst.* 16 (7), 515–579. <https://doi.org/10.17705/1jais.00403>.
- Lundgren, M., 2020. Rethinking capabilities in information security risk management: a systematic literature review. *Int. J. Risk Assess Manag.* 23 (2), 169. <https://doi.org/10.1504/IJRAM.2020.106978>.
- Luo, F., Feng, T., Zheng, L., 2021. Formal security evaluation and improvement of wireless HART protocol in Industrial wireless network. *Secur. Commun. Netw.* 2021 (1), 1–15. <https://doi.org/10.1155/2021/8090547>.
- Mizrak, F., 2023. Integrating cybersecurity risk management into strategic management: a comprehensive literature review. *Res. J. Bus. Manag.* 10 (3), 3. <https://doi.org/10.17261/Pressacademia.2023.1807>.
- Malandrin, L.J.A.A., Carvalho, T., 2013. Maintaining information security in the new technological scenario. *Pac. Asia J. Assoc. Inf. Syst.* 5 (3), 43–64. <https://doi.org/10.17705/1pais.05303>.
- Malatji, M., Marnewick, A., von Solms, S., 2020. Validation of a socio-technical management process for optimising cybersecurity practices. *Comput. Secur.* 95, 101846. <https://doi.org/10.1016/j.cose.2020.101846>.
- McFadzean, E., Ezingard, J., Birchall, D., 2007. Perception of risk and the strategic impact of existing IT on information security strategy at board level. *Online Inf. Rev.* 31 (5), 622–660. <https://doi.org/10.1108/14684520710832333>.
- McGregor, R., Reaiche, C., Boyle, S., Corral de Zubielqui, G., 2024. Cyberspace and personal cyber insurance: a systematic review. *J. Comput. Inf. Syst.* 64 (1), 157–171. <https://doi.org/10.1080/08874417.2023.2185551>.
- McInnes, L., Healy, J., & Melville, J. (2020). UMAP: uniform manifold approximation and projection for dimension reduction (No. arXiv:1802.03426). *arXiv*. <https://doi.org/10.48550/arXiv.1802.03426>.
- McIntosh, T., Liu, T., Susnjak, T., Alavizadeh, H., Ng, A., Nowrozy, R., Watters, P., 2023. Harnessing GPT-4 for generation of cybersecurity GRC policies: a focus on ransomware attack mitigation. *Comput. Secur.* 134, 103424. <https://doi.org/10.1016/j.cose.2023.103424>.
- McLeod, A., Dolezel, D., 2018. Cyber-analytics: modeling factors associated with healthcare data breaches. *Decis. Support Syst.* 108, 57–68. <https://doi.org/10.1016/j.dss.2018.02.007>.
- Meland, P.H., Bernsmed, K., Frøystad, C., Li, J., Sindre, G., 2019. An experimental evaluation of bow-tie analysis for security. *Inf. Comput. Secur.* 27 (4), 536–561. <https://doi.org/10.1108/ICS-11-2018-0132>.
- Meland, P.H., Nesheim, D.A., Bernsmed, K., Sindre, G., 2022. Assessing cyber threats for storyless systems. *J. Inf. Secur. Appl.* 64, 103050. <https://doi.org/10.1016/j.jisa.2021.103050>.
- Mizrak, F., Demirel, H.G., Yaşar, O., Karakaya, T., 2025. Digital detox: exploring the impact of cybersecurity fatigue on employee productivity and mental health. *Discov. Ment. Health* 5 (1), 25. <https://doi.org/10.1007/s44192-025-00149-x>.
- M'manga, A., Faily, S., McAlaney, J., Williams, C., Kadobayashi, Y., Miyamoto, D., 2019. A normative decision-making model for cyber security. *Inf. Comput. Secur.* 27 (5), 636–646. <https://doi.org/10.1108/ICS-01-2019-0021>.
- Mongeon, P., Paul-Hus, A., 2016. The journal coverage of Web of Science and Scopus: a comparative analysis. *Scientometrics* 106 (1), 213–228. <https://doi.org/10.1007/s11192-015-1765-5>.

- Moulavi, D., Jaskowiak, P.A., Campello, R.J., Zimek, A., Sander, J., 2014. Density-based clustering validation. In: *Proceedings of the 2014 SIAM International Conference on Data Mining. Society for Industrial and Applied Mathematics*, pp. 839–847.
- Mukhopadhyay, A., Chatterjee, S., Bagchi, K.K., Kirs, P.J., Shukla, G.K., 2019. Cyber risk assessment and mitigation (CRAM) framework using logit and probit models for Cyber insurance. *Inf. Syst. Front.* 21 (5), 997–1018. <https://doi.org/10.1007/s10796-017-9808-5>.
- Naseer, A., Naseer, H., Ahmad, A., Maynard, S.B., Siddiqui, A.M., 2023. Moving towards agile cybersecurity incident response: a case study exploring the enabling role of big data analytics-embedded dynamic capabilities. *Comput. Secur.* 135, 103525. <https://doi.org/10.1016/j.cose.2023.103525>.
- Nganga, A., Scanlan, J., Lützhöft, M., Mallam, S., 2025. Cyber risk communication during vessel incident management: a case study. *Comput. Secur.* 157, 104607. <https://doi.org/10.1016/j.cose.2025.104607>.
- NIST CSF 2.0. *The NIST Cybersecurity Framework (CSF) 2.0* (No. NIST CSWP 29; p. NIST CSWP 29). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.CSWP.29>.
- Nord, J., Sargent, C.S., Koohang, A., Marotta, A., 2022. Predictors of success in information security policy compliance. *J. Comput. Inf. Syst.* 62 (4), 863–873. <https://doi.org/10.1080/08874417.2022.2067795>.
- Norta, A., Matulevičius, R., Leiding, B., 2019. Safeguarding a formalized Blockchain-enabled identity-authentication protocol by applying security risk-oriented patterns. *Comput. Secur.* 86, 253–269. <https://doi.org/10.1016/j.cose.2019.05.017>.
- Oetzel, M.C., Spiekermann, S., 2014. A systematic methodology for privacy impact assessments: a design science approach. *Eur. J. Inf. Syst.* 23 (2), 126–150. <https://doi.org/10.1057/ejis.2013.18>.
- Page, M.J., McKenzie, J.E., Bossuyt, P.M., Boutron, I., Hoffmann, T.C., Mulrow, C.D., Shamseer, L., Tetzlaff, J.M., Akl, E.A., Brennan, S.E., Chou, R., Glanville, J., Grimshaw, J.M., Hróbjartsson, A., Lalu, M.M., Li, T., Loder, E.W., Mayo-Wilson, E., McDonald, S., Moher, D., 2021. The PRISMA 2020 statement: an updated guideline for reporting systematic reviews. *BMJ* 372, n71. <https://doi.org/10.1136/bmj.n71>.
- Paliszkiwicz, J., 2019. Information Security Policy Compliance: Leadership and Trust. *J. Comput. Inform. Syst.* 59 (3), 211–217. <https://doi.org/10.1080/08874417.2019.1571459>.
- Palma, A., Sorrentino, A., Bonomi, S., 2025. How to assess measurement capabilities of a security monitoring infrastructure and plan investment through a graph-based approach. *Expert Syst. Appl.* 262, 125623. <https://doi.org/10.1016/j.eswa.2024.125623>.
- Pan, L., Tomlinson, A., 2016. A systematic review of information security risk assessment. *Int. J. Saf. Secur. Eng.* 6 (2), 270–281. <https://doi.org/10.2495/SAFE-V6-N2-270-281>.
- Paparis, G., Zarras, A., Farao, A., Xenakis, C., 2025. CRASHED: cyber risk assessment for smart home electronic devices. *J. Inf. Secur. Appl.* 91, 104054. <https://doi.org/10.1016/j.jisa.2025.104054>.
- Paré, G., Trudel, M.-C., Jaana, M., Kitsiou, S., 2015. Synthesizing information systems knowledge: a typology of literature reviews. *Inf. Manag.* 52 (2), 183–199. <https://doi.org/10.1016/j.im.2014.08.008>.
- Paré, G., Tate, M., Johnstone, D., Kitsiou, S., 2016. Contextualizing the twin concepts of systematicity and transparency in information systems literature reviews. *Eur. J. Inf. Syst.* 25 (6), 493–508. <https://doi.org/10.1057/s41303-016-0020-3>.
- Parente, F.R., Rodrigues, E.B., Mattos, C.L.C., 2025. FRAPE: a framework for Risk assessment, prioritization and explainability of vulnerabilities in cybersecurity. *J. Inf. Secur. Appl.* 89, 103971. <https://doi.org/10.1016/j.jisa.2025.103971>.
- Patterson, C.M., Nurse, J.R.C., Franqueira, V.N.L., 2023. Learning from cyber security incidents: a systematic review and future research agenda. *Comput. Secur.* 132, 103309. <https://doi.org/10.1016/j.cose.2023.103309>.
- Peisert, S., Bishop, M., Karin, S., Marzullo, K., 2007. Analysis of computer intrusions using sequences of function calls. *IEEE Trans. Depend. Secure Comput.* 4 (2), 137–150. <https://doi.org/10.1109/TDSC.2007.1003>.
- Pham, T., Hassandoust, F., 2025. Information security policy effectiveness: a managerial perspective of the financial industry in Vietnam. *Inform. Comput. Secur.* 33 (1), 77–95.
- Pharris, L., Perez-Mira, B., 2023. Preventing social engineering: a phenomenological inquiry. *Inf. Comput. Secur.* 31 (1), 1–31. <https://doi.org/10.1108/ICS-09-2021-0137>.
- Ponemon Institute, 2025. 2025 Cybersecurity Threat and Risk Management Report. Optiv. Retrieved May 9, 2026, from <https://www.optiv.com/insights/discover/downloads/2025-cybersecurity-threat-and-risk-management-report>.
- Pool, J., Akhlaghpour, S., Fatehi, F., Burton-Jones, A., 2024. A systematic analysis of failures in protecting personal health data: a scoping review. *Int. J. Inf. Manag.* 74, 102719. <https://doi.org/10.1016/j.ijinfomgt.2023.102719>.
- Posthumus, S., von Solms, R., 2004. A framework for the governance of information security. *Comput. Secur.* 23 (8), 638–646. <https://doi.org/10.1016/j.cose.2004.10.006>.
- Proudfoot, J., Cram, W., Madnick, S., Coden, M., 2023. The importance of board member actions for cybersecurity governance and risk management. *MIS Q. Exec.* 22 (4). <http://aisel.aisnet.org/misqe/vol22/iss4/6>.
- PwC, 2025. Cyber Risk Reporting: what Boards Need from CISOs. PwC. Retrieved December 9, 2025, from <https://www.pwc.com/us/en/services/governance-insights-center/library/cyber-reporting-boards.html>.
- Qamar, S., Anwar, Z., Rahman, M.A., Al-Shaer, E., Chu, B.-T., 2017. Data-driven analytics for cyber-threat intelligence and information sharing. *Comput. Secur.* 67, 35–58. <https://doi.org/10.1016/j.cose.2017.02.005>.
- Qian, Y., Fang, Y., Gonzalez, J.J., 2012. Managing information security risks during new technology adoption. *Comput. Secur.* 31 (8), 859–869. <https://doi.org/10.1016/j.cose.2012.09.001>.
- Radunović, V., Veinović, M., Jevremović, A., 2025. The efficiency of ICT suppliers' product security incident response teams in reducing the risk of exploitation of vulnerabilities in the wild. *Comput. Secur.* 152, 104388. <https://doi.org/10.1016/j.cose.2025.104388>.
- Raha, Z.S., Khandaker, M.A.A., Hossain, M.Z., Akhter, S., 2025. Navigating high-dimensional data with advanced clustering algorithms. In: *2025 International Conference on Electrical, Computer and Communication Engineering (ECCE)*. IEEE, pp. 1–6.
- Ramezan, C.A., 2025. Understanding the chief information security officer: qualifications and responsibilities for cybersecurity leadership. *Comput. Secur.* 152, 104363. <https://doi.org/10.1016/j.cose.2025.104363>.
- Ransbotham, S., Mitra, S., 2009. Choice and chance: a conceptual model of paths to information security compromise. *Inf. Syst. Res.* 20 (1), 121–139. <https://doi.org/10.1287/isre.1080.0174>.
- Rees, J., Bandyopadhyay, S., Spafford, E.H., 2003. PFIRE: a policy framework for information security. *Commun. ACM* 46 (7), 101–106. <https://doi.org/10.1145/792704.792706>.
- Rees, L.P., Deane, J.K., Rakes, T.R., Baker, W.H., 2011. Decision support for cybersecurity risk planning. *Decis. Support Syst.* 51 (3), 493–505. <https://doi.org/10.1016/j.dss.2011.02.013>.
- Reeves, A., Delfabbro, P., Calic, D., 2021. Encouraging employee engagement with cybersecurity: how to tackle cyber fatigue. *Sage Open* 11 (1), 21582440211000049. <https://doi.org/10.1177/21582440211000049>.
- Rhee, H.-S., Ryu, Y.U., Kim, C.-T., 2012. Unrealistic optimism on information security management. *Comput. Secur.* 31 (2), 221–232. <https://doi.org/10.1016/j.cose.2011.12.001>.
- Rocha Flores, W., Ekstedt, M., 2016. Shaping intention to resist social engineering through transformational leadership, information security culture and awareness. *Comput. Secur.* 59, 26–44. <https://doi.org/10.1016/j.cose.2016.01.004>.
- Rocha Flores, W., Antonsen, E., Ekstedt, M., 2014. Information security knowledge sharing in organizations: investigating the effect of behavioral information security governance and national culture. *Comput. Secur.* 43, 90–110. <https://doi.org/10.1016/j.cose.2014.03.004>.
- Ryan, J.J.C.H., Ryan, D.J., 2006. Expected benefits of information security investments. *Comput. Secur.* 25 (8), 579–588. <https://doi.org/10.1016/j.cose.2006.08.001>.
- Safa, N.S., Von Solms, R., Furnell, S., 2016. Information security policy compliance model in organizations. *Comput. Secur.* 56, 70–82.
- Samtani, S., Chai, Y., Chen, H., 2022. Linking exploits from the dark web to known vulnerabilities for proactive cyber threat intelligence: an attention-based deep structured semantic model. *MIS Q.* 46 (2), 911–946.
- Santini, P., Gottardi, G., Baldi, M., Chiaraluce, F., 2019. A data-driven approach to cyber risk assessment. *Secur. Commun. Netw.* 2019 (1), 6716918. <https://doi.org/10.1155/2019/6716918>.
- Schinagl, S., Shahim, A., Khapova, S., 2022. Paradoxical tensions in the implementation of digital security governance: toward an ambidextrous approach to governing digital security. *Comput. Secur.* 122, 102903. <https://doi.org/10.1016/j.cose.2022.102903>.
- Schmitz, C., Pape, S., 2020. LiSRA: lightweight security risk assessment for decision support in information security. *Comput. Secur.* 90, 101656. <https://doi.org/10.1016/j.cose.2019.101656>.
- Sen, R., Borle, S., 2015. Estimating the contextual risk of data breach: an empirical approach. *J. Manag. Inf. Syst.* 32 (2), 314–341. <https://doi.org/10.1080/07421222.2015.1063315>.
- Shamala, P., Ahmad, R., Zolait, A., Sedek, M., 2017. Integrating information quality dimensions into information security risk management (ISRM). *J. Inf. Secur. Appl.* 36, 1–10. <https://doi.org/10.1016/j.jisa.2017.07.004>.
- Shameli-Sendi, A., Aghababaei-Barzegar, R., Cheriet, M., 2016. Taxonomy of information security risk assessment (ISRA). *Comput. Secur.* 57, 14–30. <https://doi.org/10.1016/j.cose.2015.11.001>.
- Shameli-Sendi, A., 2020. An efficient security data-driven approach for implementing risk assessment. *J. Inf. Secur. Appl.* 54, 102593. <https://doi.org/10.1016/j.jisa.2020.102593>.
- Shang, W., Gong, T., Chen, C., Hou, J., Zeng, P., 2019. Information security risk assessment method for ship control system based on fuzzy sets and attack trees. *Secur. Commun. Netw.* 2019 (1), 1–11. <https://doi.org/10.1155/2019/3574675>.
- Sharma, K., Mukhopadhyay, A., 2021. Kernel naïve Bayes classifier-based cyber-risk assessment and mitigation framework for online gaming platforms. *J. Organ. Comput. Electron. Commer.* 31 (4), 343–363. <https://doi.org/10.1080/10919392.2021.1987790>.
- Sharma, K., Mukhopadhyay, A., 2023. Cyber-risk management framework for online gaming firms: an artificial neural network approach. *Inf. Syst. Front.* 25 (5), 1757–1778. <https://doi.org/10.1007/s10796-021-10232-7>.
- Sharma, S., Routroy, S., 2016. Modeling information risk in supply chain using Bayesian networks. *J. Enterp. Inf. Manag.* 29 (2), 238–254. <https://doi.org/10.1108/JEIM-03-2014-0031>.
- Shin, B., Lowry, P.B., 2020. A review and theoretical explanation of the 'Cyberthreat-Intelligence (CTI) capability' that needs to be fostered in information security practitioners and how this can be accomplished. *Comput. Secur.* 92, 101761. <https://doi.org/10.1016/j.cose.2020.101761>.
- Silaile, C.B., Makhubele, L.M., Mamorobela, S.P., 2022. A model to reduce insider cybersecurity threats in a South African telecommunications company. *S. Afr. J. Inf. Manag.* 24 (1), 1573.
- Silva, M.M., de Gusmão, A.P.H., Poletto, T., Silva, L.C.e, Costa, A.P.C.S., 2014. A multidimensional approach to information security risk management using FMEA and fuzzy theory. *Int. J. Inf. Manag.* 34 (6), 733–740. <https://doi.org/10.1016/j.ijinfomgt.2014.07.005>.

- Slapnicar, S., Vidmar, T., Tsen, E., 2025. Process theory of supplier cyber risk assessment. *Australas. J. Inf. Syst.* 29. <https://doi.org/10.3127/ajis.v29.5323>.
- Solic, K., Ocevci, H., Golub, M., 2015. The information systems' security level assessment model based on an ontology and evidential reasoning approach. *Comput. Secur.* 55, 100–112. <https://doi.org/10.1016/j.cose.2015.08.004>.
- Spears, J.L., Barki, H., 2010. User participation in Information systems Security risk management. *MIS Q.* 34 (3), 503–522. <https://doi.org/10.2307/25750689>.
- Spears, J., 2018. Gaining real-world experience in information security: a roadmap for a service-learning course. *J. Inf. Syst. Educ.* 29 (4), 183–202.
- Spence, M., 1973. Job market signaling. *Q. J. Econ.* 87 (3), 355. <https://doi.org/10.2307/1882010>.
- Stergiopoulos, G., Dedousis, P., Gritzalis, D., 2020. Automatic network restructuring and risk mitigation through business process asset dependency analysis. *Comput. Secur.* 96, 101869. <https://doi.org/10.1016/j.cose.2020.101869>.
- Stewart, H., Jürjens, J., 2017. Information security management and the human aspect in organizations. *Inf. Comput. Secur.* 25 (5), 494–534. <https://doi.org/10.1108/ICS-07-2016-0054>.
- Suchman, M.C., 1995. Managing legitimacy: strategic and institutional approaches. *Acad. Manag. Rev.* 20 (3), 571. <https://doi.org/10.2307/258788>.
- Sun, L., Srivastava, R.P., Mock, T.J., 2006. An information systems security risk assessment model under the Dempster-Shafer theory of belief functions. *J. Manag. Inf. Syst.* 22 (4), 109–142. <https://doi.org/10.2753/MIS0742-1222220405>.
- Sunikka, A., Bragge, J., 2012. Applying text-mining to personalization and customization research literature – Who, what and where? *Expert Syst. Appl.* 39 (11), 10049–10058. <https://doi.org/10.1016/j.eswa.2012.02.042>.
- Tamrin, S.I., Norman, A.A., Hamid, S., 2017. Information systems security practices in social software applications: a systematic literature review. *Aslib J. Inf. Manag.* 69 (2), 131–157. <https://doi.org/10.1108/AJIM-08-2016-0124>.
- Tang, J., Akram, U., Shi, W., 2021. Why people need privacy? The role of privacy fatigue in app users' intention to disclose privacy: based on personality traits. *J. Enterp. Inf. Manag.* 34 (4), 1097–1120. <https://doi.org/10.1108/JEIM-03-2020-0088>.
- Tarafdar, P., Bose, I., 2019. Systems theoretic process analysis of information security: the case of aadhaar. *J. Organ. Comput. Electron. Commer.* 29 (3), 209–222. <https://doi.org/10.1080/10919392.2019.1598608>.
- Teece, D.J., Pisano, G., Shuen, A., 1997. Dynamic capabilities and strategic management. *Strateg. Manag. J.* 18 (7), 509–533. [https://doi.org/10.1002/\(SICI\)1097-0266\(199708\)18:7<509::AID-MJ882>3.0.CO;2-Z](https://doi.org/10.1002/(SICI)1097-0266(199708)18:7<509::AID-MJ882>3.0.CO;2-Z).
- Thompson, N., Mullins, A., Chongsutakawong, T., 2020. Does high e-government adoption assure stronger security? Results from a cross-country analysis of Australia and Thailand. *Gov. Inf. Q.* 37 (1), 101408. <https://doi.org/10.1016/j.giq.2019.101408>.
- Tryfonas, T., Sutherland, I., Pompogiatzis, I., 2007. Employing penetration testing as an audit methodology for the security review of VoIP: tests and examples. *Internet Res.* 17 (1), 61–87. <https://doi.org/10.1108/10662240710730506>.
- Tsen, E., Ko, R.K.L., Slapnicar, S., 2022. An exploratory study of organizational cyber resilience, its precursors and outcomes. *J. Organ. Comput. Electron. Commer.* 32 (2), 153–174. <https://doi.org/10.1080/10919392.2022.2068906>.
- Tubío Figueira, P., López Bravo, C., Rivas López, J.L., 2020. Improving information security risk analysis by including threat-occurrence predictive models. *Comput. Secur.* 88, 101609. <https://doi.org/10.1016/j.cose.2019.101609>.
- Turel, O., Xu, Z., Guo, K., 2020. Organizational citizenship behavior regarding security: leadership approach perspective. *J. Comput. Inf. Syst.* 60 (1), 61–75. <https://doi.org/10.1080/08874417.2017.1400928>.
- Tushman, M.L., Nadler, D.A., 1978. Information processing as an integrating concept in organizational design. *Acad. Manag. Rev.* 3 (3), 613–624. <https://doi.org/10.5465/amr.1978.4305791>.
- Van der Kleij, R., Kleinhuis, G., Young, H., 2017. Computer security incident response team effectiveness: a Needs assessment. *Front. Psychol.* 8. <https://doi.org/10.3389/fpsyg.2017.02179>.
- van Schaik, P., Jeske, D., Onibokun, J., Coventry, L., Jansen, J., Kusev, P., 2017. Risk perceptions of cyber-security and precautionary behaviour. *Comput. Hum. Behav.* 75, 547–559. <https://doi.org/10.1016/j.chb.2017.05.038>.
- Vance, A., Siponen, M., Pahnla, S., 2012. Motivating IS security compliance: insights from habit and protection motivation theory. *Inf. Manag.* 49, 190–198. <https://doi.org/10.1016/j.im.2012.04.002>.
- Varga, S., Brynielsson, J., Franke, U., 2021. Cyber-threat perception and risk management in the Swedish financial sector. *Comput. Secur.* 105, 102239. <https://doi.org/10.1016/j.cose.2021.102239>.
- Vaughn, R.B., Henning, R., Fox, K., 2002. An empirical study of industrial security-engineering practices. *J. Syst. Softw.* 61 (3), 225–232. [https://doi.org/10.1016/S0164-1212\(01\)00150-9](https://doi.org/10.1016/S0164-1212(01)00150-9).
- Veiga, A.D., Eloff, J.H.P., 2007. An information security governance framework. *Inf. Syst. Manag.* 24 (4), 361–372. <https://doi.org/10.1080/10580530701586136>.
- Verizon, 2025. Verizon's 2025 Data Breach Investigations report: alarming surge in cyberattacks through third-parties. <http://corpweb-api.verizon.com/about/news/2025-data-breach-investigations-report>.
- Villalón-Fonseca, R., 2022. The nature of security: a conceptual framework for integral-comprehensive modeling of IT security and cybersecurity. *Comput. Secur.* 120, 102805. <https://doi.org/10.1016/j.cose.2022.102805>.
- Vitunskaitė, M., He, Y., Brandstetter, T., Janicke, H., 2019. Smart cities and cyber security: are we there yet? A comparative study on the role of standards, third party risk management and security ownership. *Comput. Secur.* 83, 313–331. <https://doi.org/10.1016/j.cose.2019.02.009>.
- Von Solms, R., von Solms, S.H., 2006. Information security governance: a model based on the direct–Control cycle. *Comput. Secur.* 25 (6), 408–412. <https://doi.org/10.1016/j.cose.2006.07.005>.
- Von Solms, R., von Solms, S.H., 2006. Information security governance: due care. *Comput. Secur.* 25 (7), 494–497. <https://doi.org/10.1016/j.cose.2006.08.013>.
- Von Solms, B., 2005. Information Security governance: COBIT or ISO 17799 or both? *Comput. Secur.* 24 (2), 99–104. <https://doi.org/10.1016/j.cose.2005.02.002>.
- Von Solms, S.H., 2005. Information Security governance – Compliance management vs operational management. *Comput. Secur.* 24 (6), 443–447. <https://doi.org/10.1016/j.cose.2005.07.003>.
- Von Solms, B., 2006. Information security – the fourth wave. *Comput. Secur.* 25 (3), 165–168. <https://doi.org/10.1016/j.cose.2006.03.004>.
- Wang, J., Chaudhury, A., Rao, H.R., 2008. Research note—A value-at-risk approach to information security investment. *Inf. Syst. Res.* 19 (1), 106–120. <https://doi.org/10.1287/isre.1070.0143>.
- Wang, T., Kannan, K.N., Ulmer, J.R., 2013. The association between the disclosure and the realization of information security risk factors. *Inf. Syst. Res.* 24 (2), 201–218. <https://doi.org/10.1287/isre.1120.0437>.
- Wang, J., Gupta, M., Rao, H.R., 2015. Insider threats in a financial institution: analysis of attack-proneness of information systems applications. *MIS Q.* 39 (1), 91–112.
- Wang, J., Nie, L., Duan, J., Zhao, H., Chen, C.L.P., 2025. Mixture-of-experts-based broad learning system and its applications. *Expert Syst. Appl.* 269, 126389. <https://doi.org/10.1016/j.eswa.2025.126389>.
- Webb, J., Ahmad, A., Maynard, S.B., Shanks, G., 2014. A situation awareness model for information security risk management. *Comput. Secur.* 44, 1–15. <https://doi.org/10.1016/j.cose.2014.04.005>.
- Webb, S., 2000. Crimes and misdemeanours: how to protect corporate information in the Internet age. *Comput. Secur.* 19 (2), 128–132. [https://doi.org/10.1016/S0167-4048\(00\)87822-0](https://doi.org/10.1016/S0167-4048(00)87822-0).
- Woods, D.W., 2023. A turning point for cyber insurance. *Commun. ACM* 66 (3), 41–44. <https://doi.org/10.1145/3545795>.
- Wu, Y., Wang, L., Cheng, D., Dai, T., 2021. Information security decisions of firms considering security risk interdependency. *Expert Syst. Appl.* 178, 114990. <https://doi.org/10.1016/j.eswa.2021.114990>.
- Xiong, W., Lagerström, R., 2019. Threat modeling – a systematic literature review. *Comput. Secur.* 84, 53–69. <https://doi.org/10.1016/j.cose.2019.03.010>.
- Xu, W., Murphy, F., Xu, X., Xing, W., 2021. Dynamic communication and perception of cyber risk: evidence from big data in media. *Comput. Hum. Behav.* 122, 106851. <https://doi.org/10.1016/j.chb.2021.106851>.
- Yang, H., Lin, Z., Chen, X., Peng, J., 2023. Workplace loneliness, ego depletion and cyberloafing: can leader problem-focused interpersonal emotion management help? *Internet Res.* 33 (4), 1473–1494. <https://doi.org/10.1108/INTR-01-2021-0007>.
- Yoon, C., Hwang, J.-W., Kim, R., 2012. Exploring factors that influence students' Behaviors in information security. *J. Inf. Syst. Educ.* 23 (4), 407–416.
- Yousaf, A., Gunawan, S., Basnet, S., Bolbot, V., Zhou, J., Valdez Banda, O.A., 2025. STPA-Cyber: a semi-automated cyber risk assessment framework for maritime cybersecurity. *Comput. Secur.* 157, 104559. <https://doi.org/10.1016/j.cose.2025.104559>.
- Zhang, Y., Jin, R., Zhou, Z.-H., 2010. Understanding bag-of-words model: a statistical framework. *Int. J. Mach. Learn. Cybern.* 1 (1), 43–52. <https://doi.org/10.1007/s13042-010-0001-0>.